Stony Brook University

CSE 508

Network Security
(Lecture 3- Symmetric Key Cryptography)

Omar Haider Chowdhury
Empire Innovation Scholar and Associate Professor
Department of Computer Science
Stony Brook University

Modules

Stony Brook University

- This class will have the following modules:
  - Background:
    - Cryptography
    - Introduction to Network and Protocols
  - Authentication
  - Access Control
  - Attacks and Defenses against protocols
  - Essential tools for attack and defense
  - Web Security
  - Privacy and Anonymity
  - Advanced Topics (Protocol Verification)

Modules

Stony Brook University

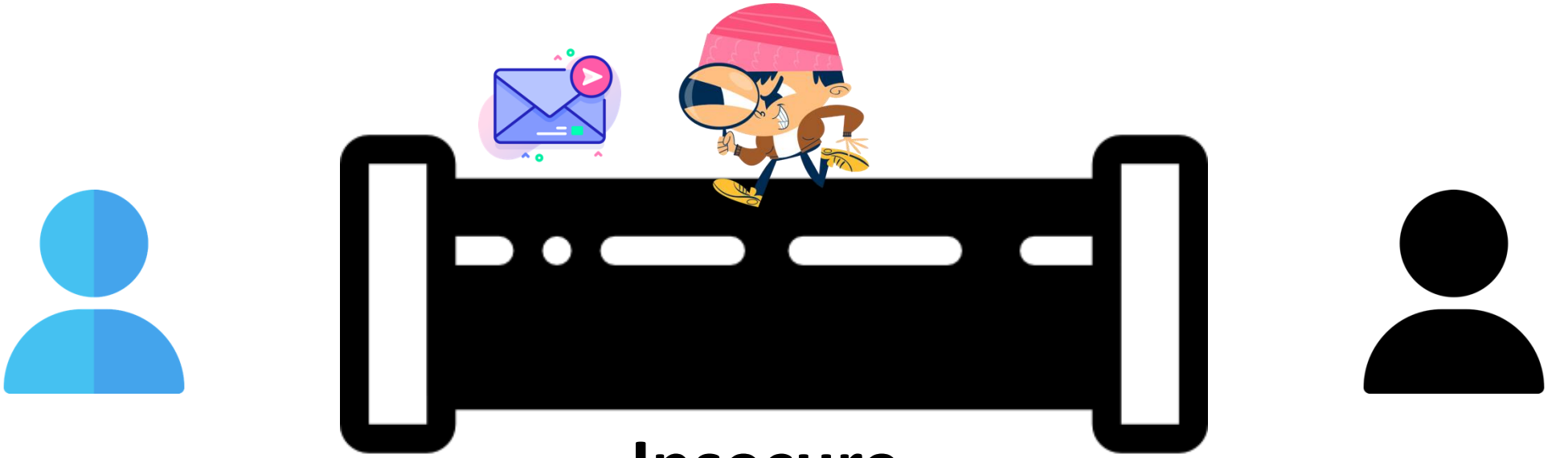
- This class will have the following modules:
  - Background:
    - Cryptography
    - Introduction to Network and Protocols
  - Authentication
  - Access Control
  - Attacks and Defenses against protocols
  - Essential tools for attack and defense
  - Web Security
  - Privacy and Anonymity
  - Advanced Topics (Protocol Verification)

Terminology

Cryptography Goals

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **<u>security of communication</u>** over **<u>insecure medium</u>**



Sender

Insecure communication channel

Receiver

Computer Security

Stony Brook University

- **Security** = *Sustain desirable properties under intelligent adversaries*

- **Desirable properties**
  - Understand what properties are needed.
- **Intelligent adversaries**
  - Needs to understand/model adversaries
  - Always think about adversaries.

What does secure comm mean?

What does secure comm mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **<u>security of communication</u>** over **insecure medium**

What does secure comm mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **<u>security of communication</u>** over **insecure medium**
- What does secure communication mean?

What does secure comm mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **<u>security of communication</u>** over **insecure medium**
- What does secure communication mean?
  - **Confidentiality** (secrecy)
    - Only the intended receiver can understand the meaning of a secret communication

What does secure comm mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **<u>security of communication</u>** over **insecure medium**
- What does secure communication mean?
  - **Confidentiality** (secrecy)
    - Only the intended receiver can understand the meaning of a secret communication
  - **Integrity** (authenticity)
    - The communication is generated by the alleged sender
    - *<u>Any unauthorized perturbation of the communication can be detected by the receiver</u>*

What does insecure medium mean?

What does insecure medium mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **security of communication** over **<u>insecure medium</u>**

What does insecure medium mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **security of communication** over **<u>insecure medium</u>**
- What does insecure medium mean?

What does insecure medium mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **security of communication** over **<u>insecure medium</u>**
- What does insecure medium mean?
  - **Passive Attacker**
    - The attacker can only eavesdrop

What does insecure medium mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **security of communication** over **<u>insecure medium</u>**
- What does insecure medium mean?
  - **Passive Attacker**
    - The attacker can only eavesdrop
  - **Active Attacker**
    - The attacker has <u>full control</u> over the channel
    - *Eavesdrop, drop messages, swap messages, impersonate sender*

Approaches to secure communication

Stony Brook University

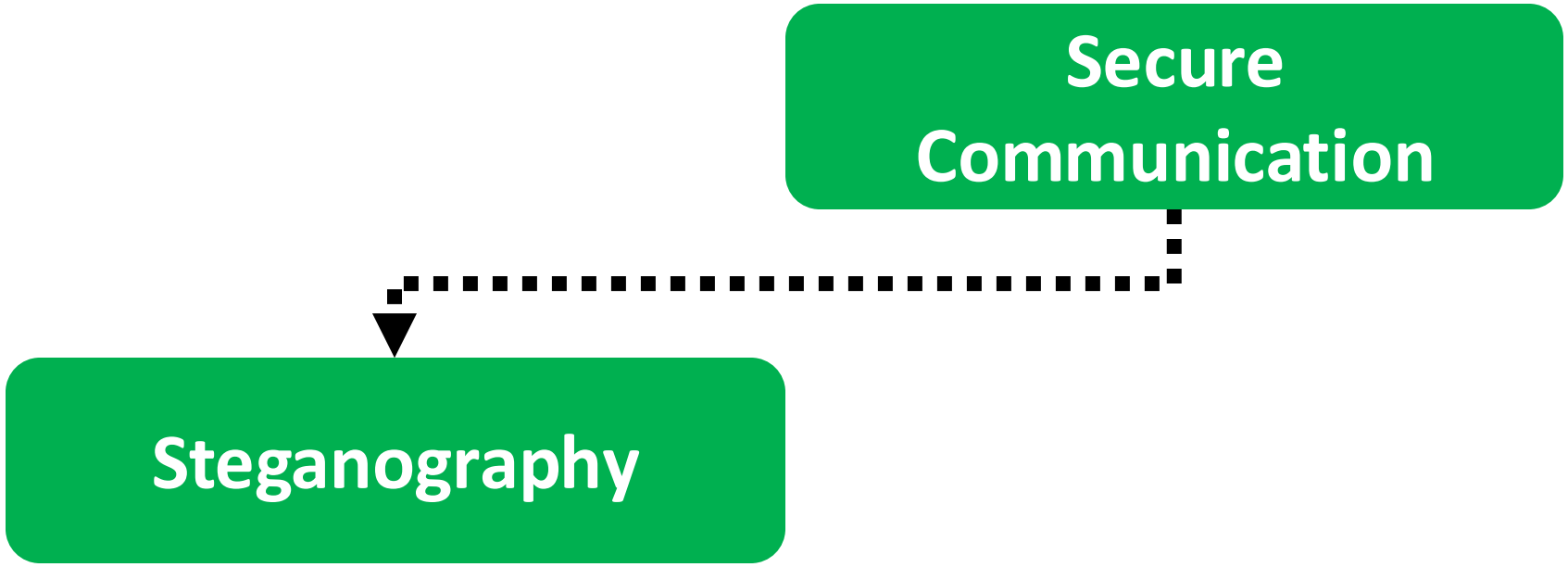
Approaches to secure communication

Stony Brook University

Secure Communication

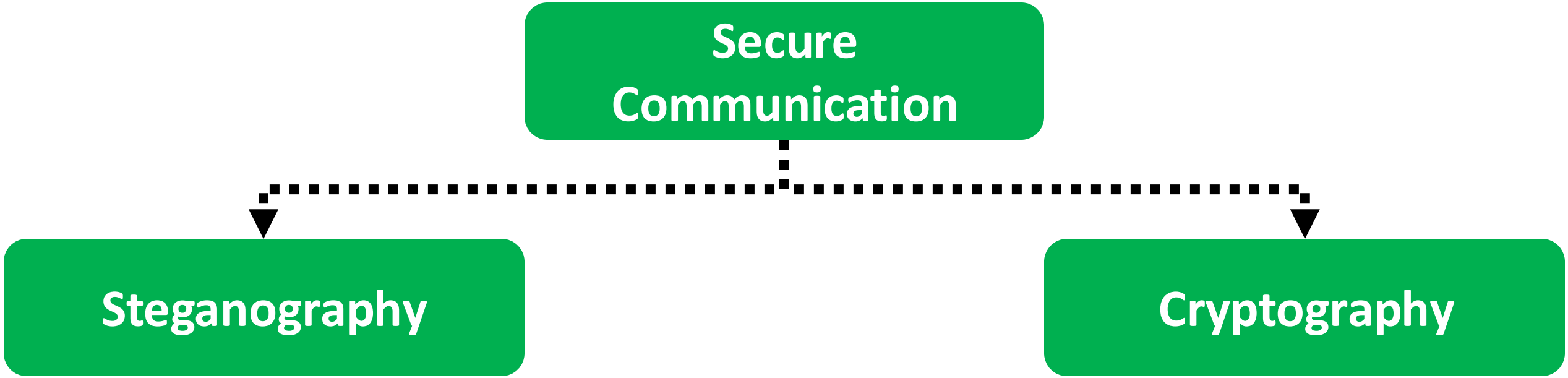
Approaches to secure communication

Stony Brook University



Approaches to secure communication

Stony Brook University



Approaches to secure communication

Stony Brook University

Secure Communication

Steganography

- "Covered writing"
- Hides the existence of a message
- Security depends on the secrecy of the method

Cryptography

Approaches to secure communication

Stony Brook University

Secure Communication

Steganography

- "Covered writing"
- Hides the existence of a message
- Security depends on the secrecy of the method

Cryptography

- "Hidden writing"
- Hides the message semantics
- Security depends on the secrecy of a key, <u>not the method</u>

Approaches to secure communication

Stony Brook University

Secure Communication

Focus

Steganography

- "Covered writing"
- Hides the existence of a message
- Security depends on the secrecy of the method

Cryptography

- "Hidden writing"
- Hides the message semantics
- Security depends on the secrecy of a key, <u>not the method</u>

Steganography

Steganography

Stony Brook University

- **Historical Usages**:
  - Wax tablet
    - Spartan war against Persia
  - Invisible ink
  - Message tattooed in a scalp

History of steganography: http://5010.mathed.usu.edu/Fall2014/KKing/historysteganography.html

Steganography

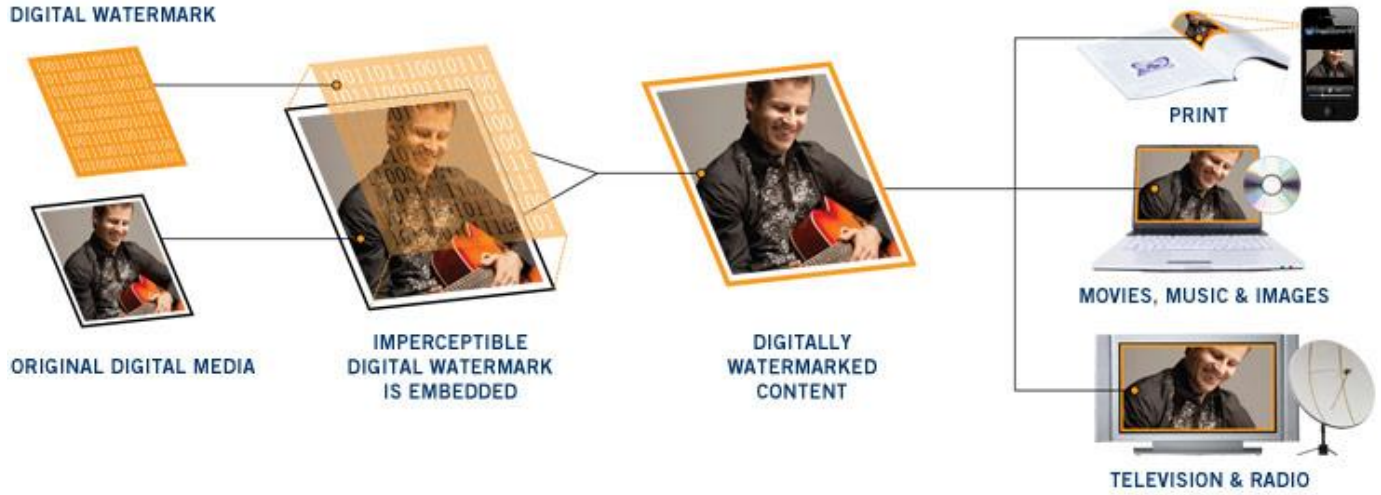
Stony Brook University

- **Historical Usages**:
  - Wax tablet
    - Spartan war against Persia
  - Invisible ink
  - Message tattooed in a scalp
- **Modern Use cases**:
  - Microdots
    - Germans during WWII
  - Terrorists communicating with each other
  - Watermarking digital contents
  - Censorship circumvention
  - Digital Rights Management (DRM)

History of steganography: http://5010.mathed.usu.edu/Fall2014/KKing/historysteganography.html

Digital Watermarking

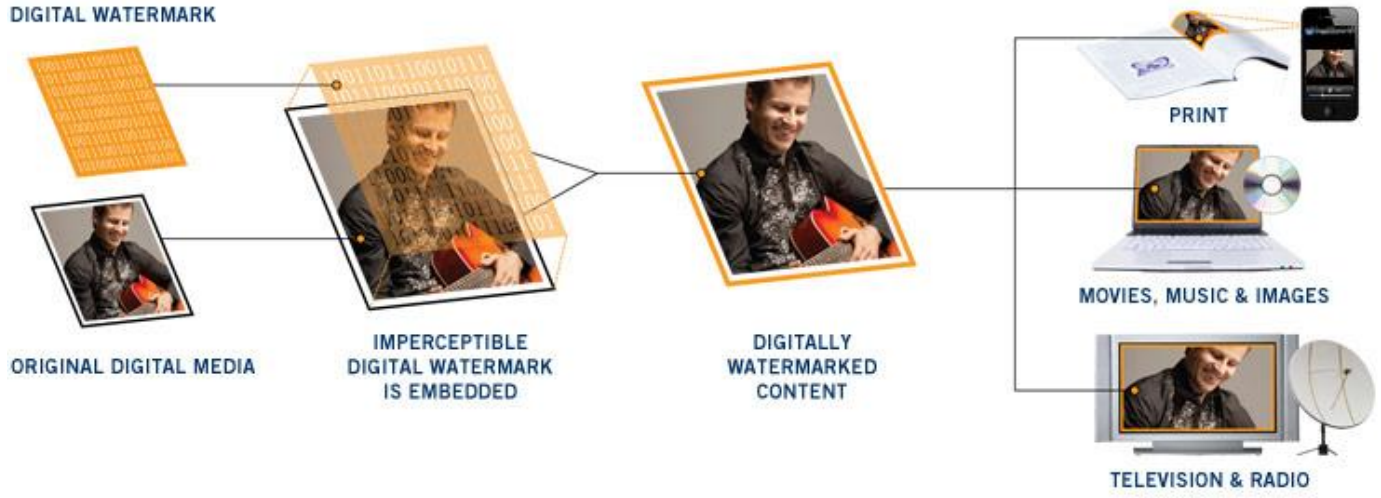
Digital Watermarking



Mainly used for images and audio

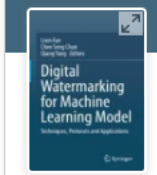
Digital Watermarking

Stony Brook University



Yes We can: Watermarking machine learning models beyond classification

Lounici Sofiane, Mohamed Njeh, Orhan Ermis, Melek Önen, Slim Trabelsi



Book | © 2023

Digital Watermarking for Machine Learning Model

Techniques, Protocols and Applications

27TH USENIX SECURITY SYMPOSIUM ATTEND PROGRAM PARTICIPATE SPONSORSHIP ABOUT

Turning Your Weakness Into a Strength: Watermarking Deep Neural Networks by Backdooring

Authors:
Yossi Adi and Carsten Baum, *Bar Ilan University;* Moustapha Cisse, *Google Inc;* Benny Pinkas and Joseph Keshet, *Bar Ilan University*

NEWS

To Protect Machine Learning IP, Model Watermarking Is on the Rise

February 08, 2023 by Jake Hertz

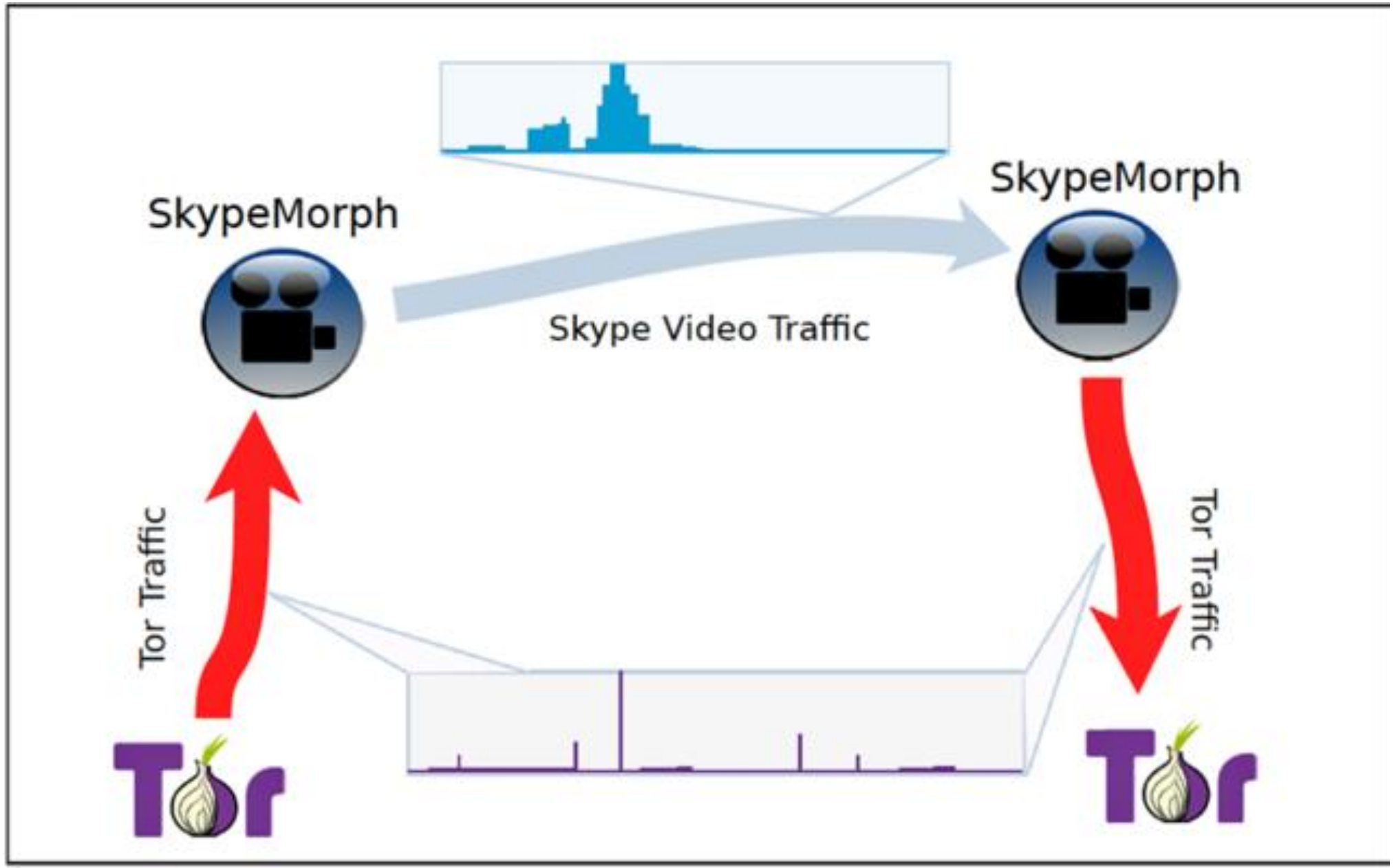
ML Model Watermarking

REUSE compliant | License Apache 2.0

Protect your machine learning models easily and securely with watermarking 🔑

Censorship Circumvention

Stony Brook University



Digital Rights Management

Stony Brook University

Spotify

hulu
COME TV WITH US

iTunes

NETFLIX

amazon music

Digital Rights Management

Stony Brook University

Spotify®

Microsoft® PlayReady®

hulu
COME TV WITH US

iTunes

NETFLIX

amazonmusic

Digital Rights Management

Stony Brook University

Spotify

Microsoft PlayReady

hulu
COME TV WITH US

iTunes

NETFLIX

amazon music

TECH / HP / REPORT

HP has found an exciting new way to DRM your printer!

HP Printers Are Doing the DRM Thing Again

HP customers complain that their perfectly good printers are now rejecting perfectly good third-party ink.

Digital Rights Management

Stony Brook University

Spotify

Microsoft PlayReady

hulu
COME TV WITH US

iTunes

NETFLIX

amazon music

TECH / HP / REPORT

HP has found an exciting new way to DRM your printer!

HP Printers Are Doing the DRM Thing Again

HP customers complain that their perfectly good printers are now rejecting perfectly good third-party ink.

Farmers avoid buying John Deere tractors because of their DRM software

Benjamin Rosa • 23 January 2020 0 13.677 2 reading minutes

Digital Rights Management

Stony Brook University

Spotify

Microsoft PlayReady

TECH / HP / REPORT

HP has found an exciting new way to DRM your printer!

hulu
COME TV WITH US

iTunes

HP Printers Are Doing the DRM Thing Again

HP customers complain that their perfectly good printers are now rejecting perfectly good third-party ink.

NETFLIX

amazon music

Farmers avoid buying John Deere tractors because of their DRM software

Benjamin Rosa • 23 January 2020 0 13.677 2 reading minutes

LILY HAY NEWMAN SECURITY AUG 13, 2022 9:31 PM

A New Jailbreak for John Deere Tractors Rides the Right-to-Repair Wave

A hacker has formulated an exploit that provides root access to two popular models of the company's farm equipment.

Cryptography

Terminology (Confidentiality)

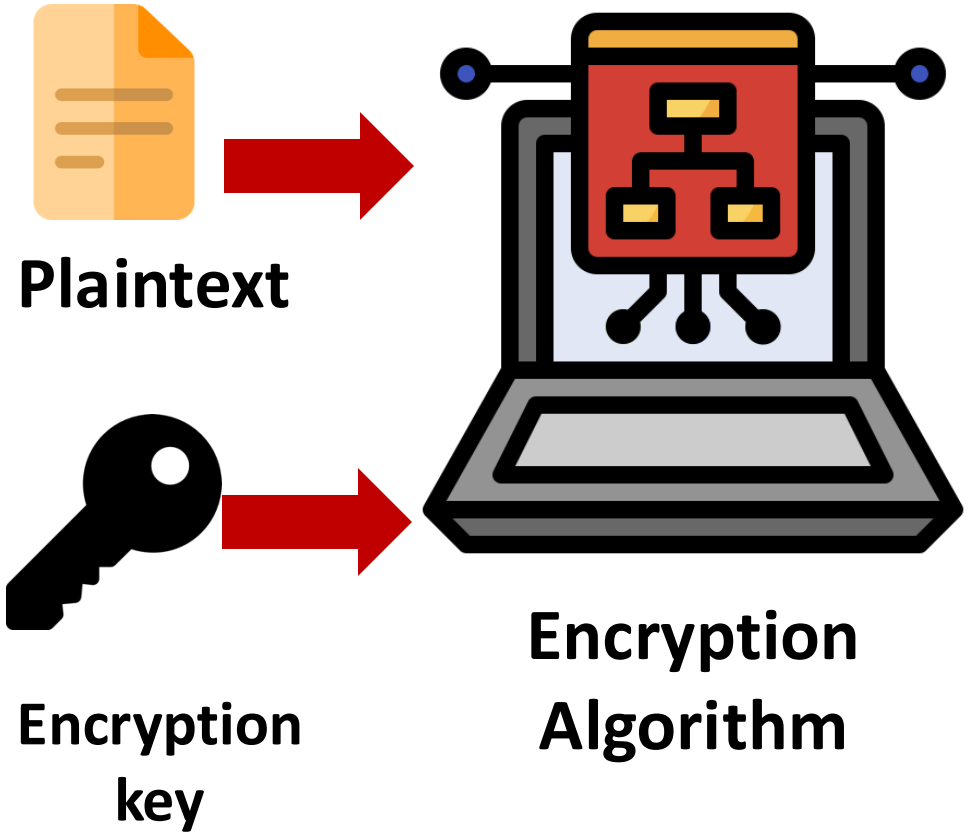
- **Plaintext**
  - The original secret message that the sender wants to protect from eavesdropping
- **Ciphertext**
  - The original message after transformation
- **Key**
  - The secret used to transform “Plaintext”
- **Encryption**
- **Decryption**
- **Cipher**
  - Algorithm for encryption and decryption

Encryption and Decryption

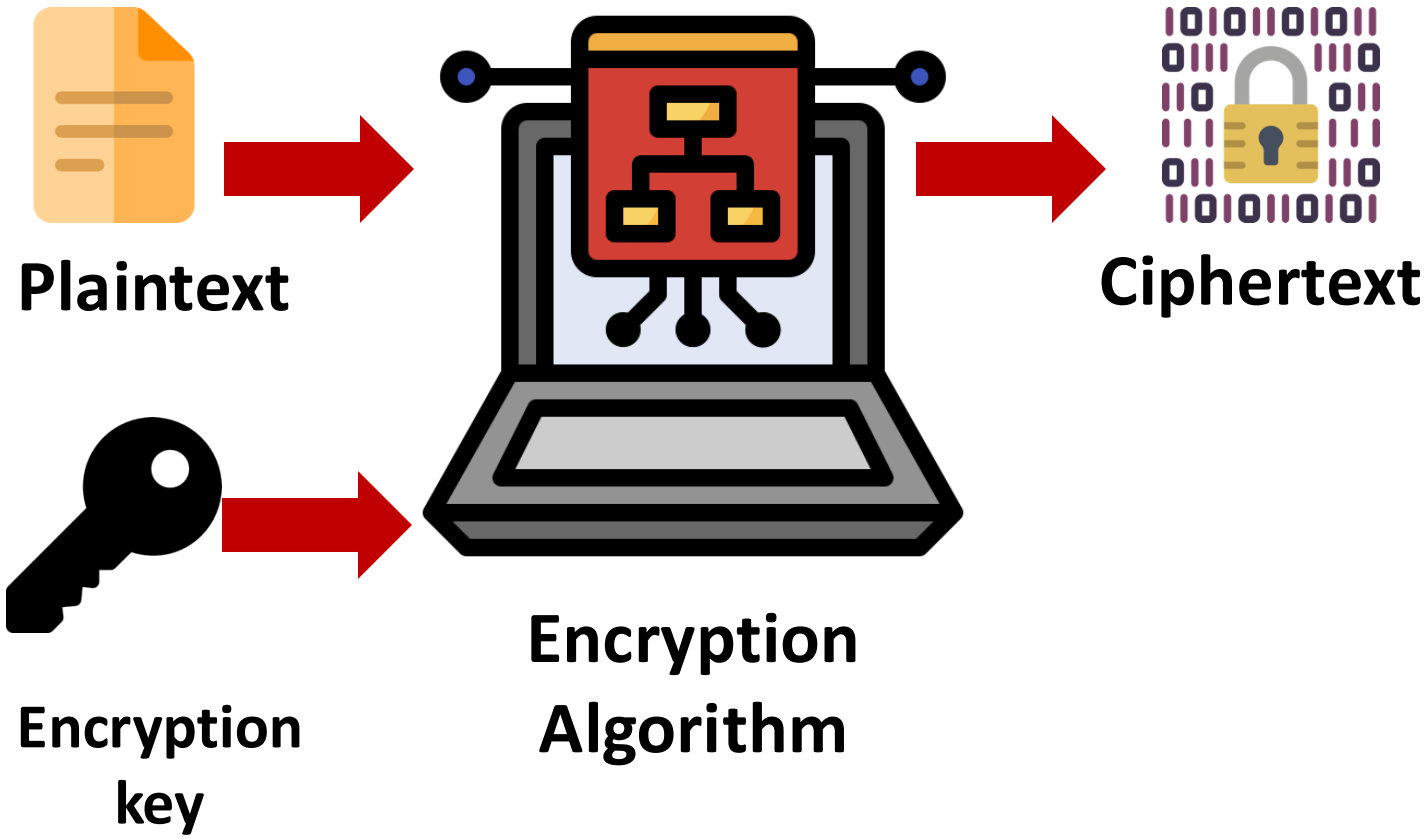
Encryption and Decryption

Plaintext

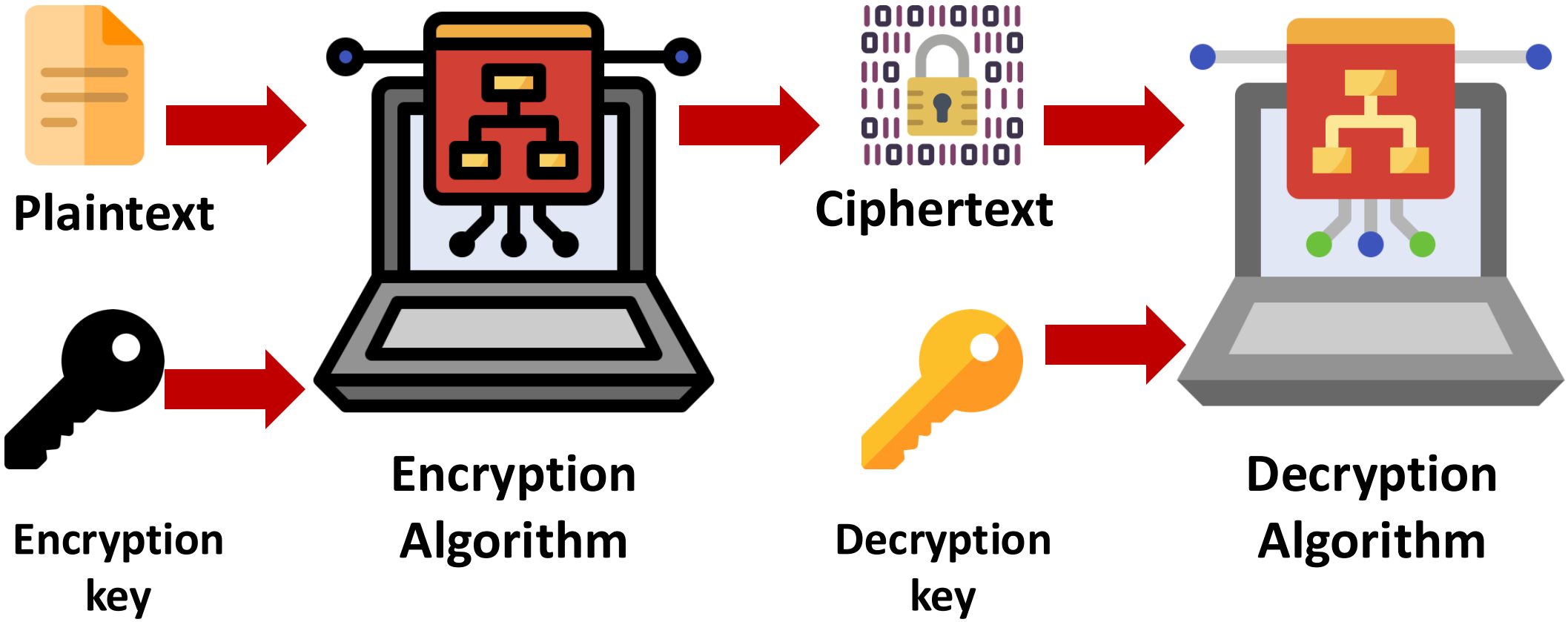
Encryption and Decryption



Encryption and Decryption

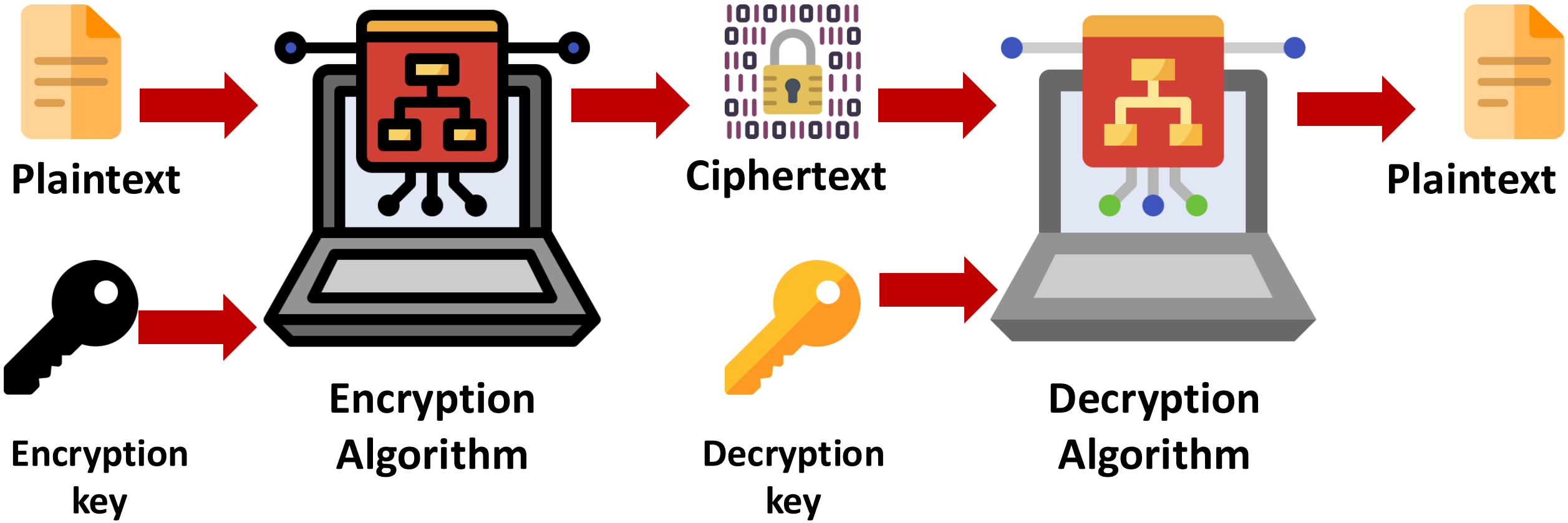


Encryption and Decryption



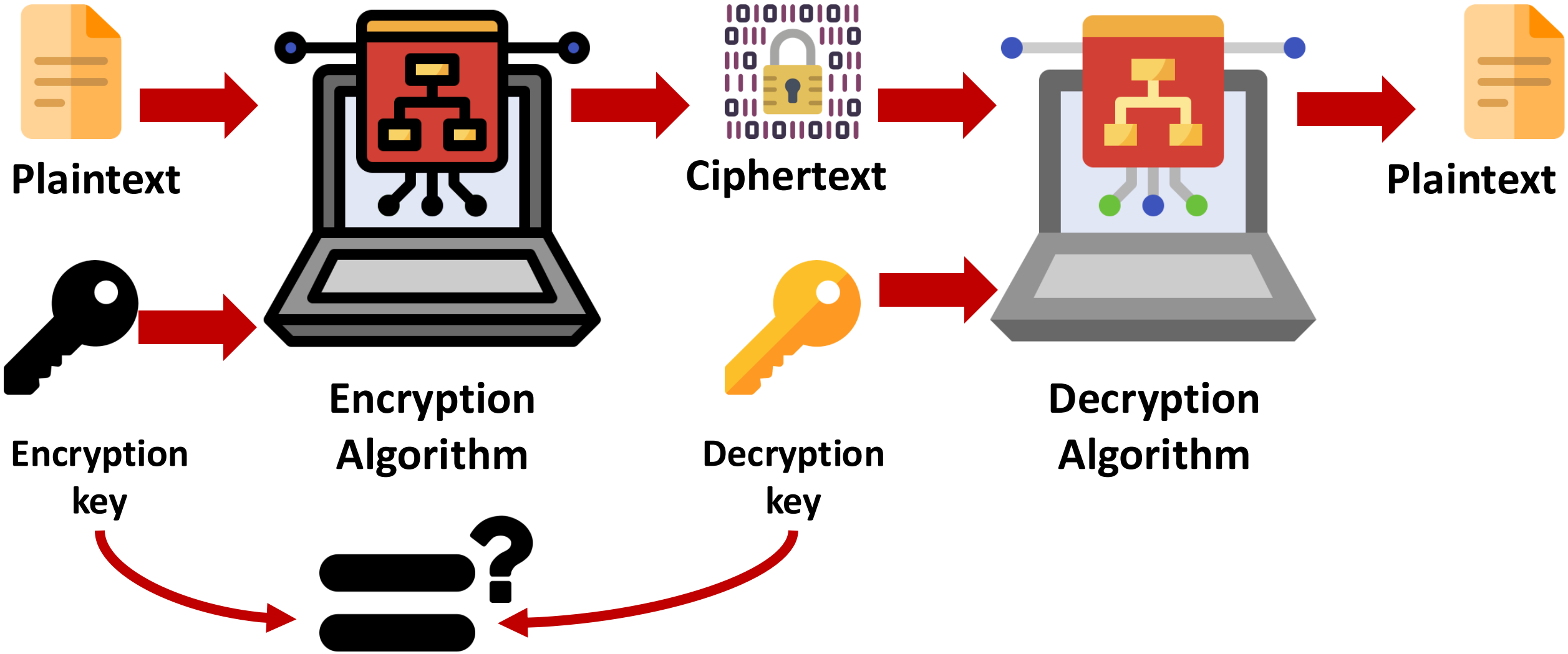
Encryption and Decryption

Stony Brook University



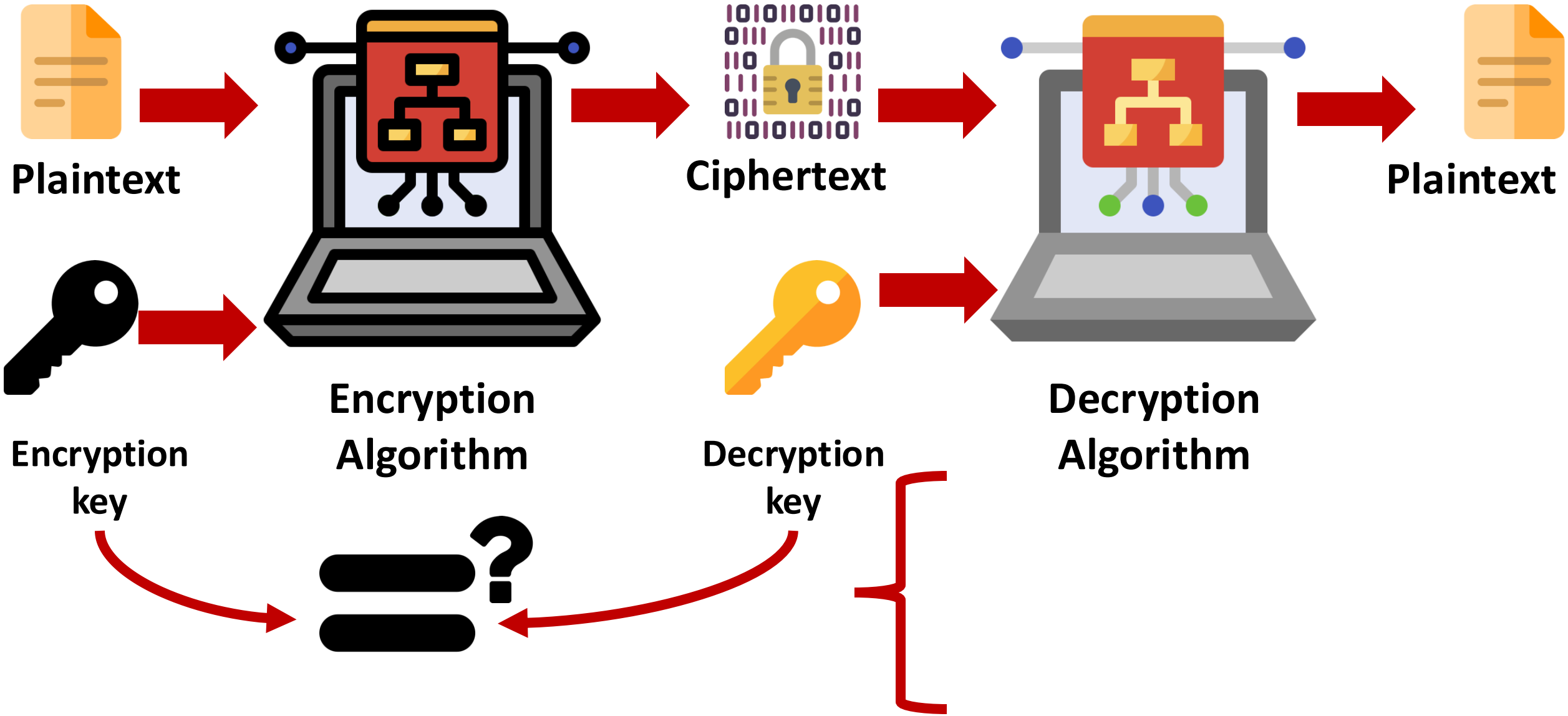
Encryption and Decryption

Stony Brook University



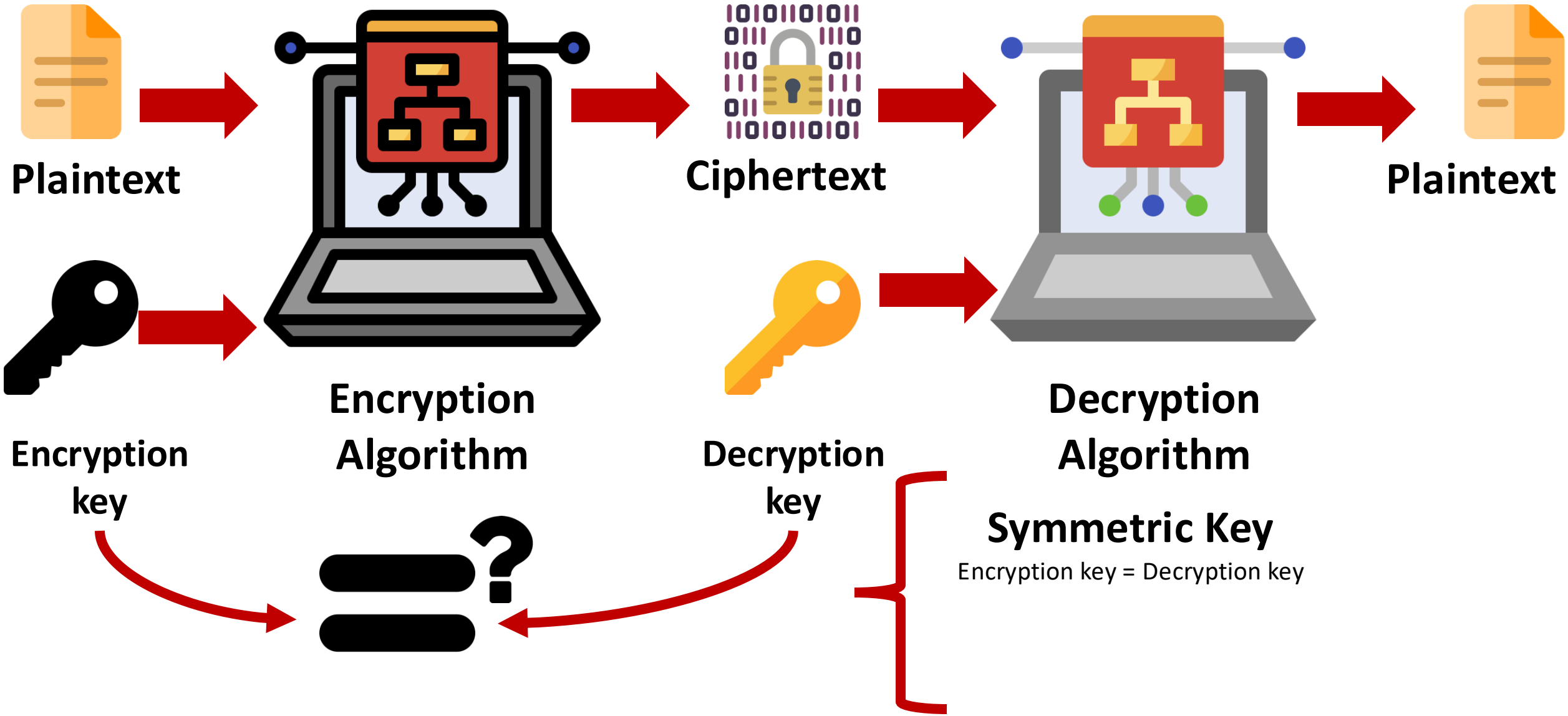
Encryption and Decryption

Stony Brook University



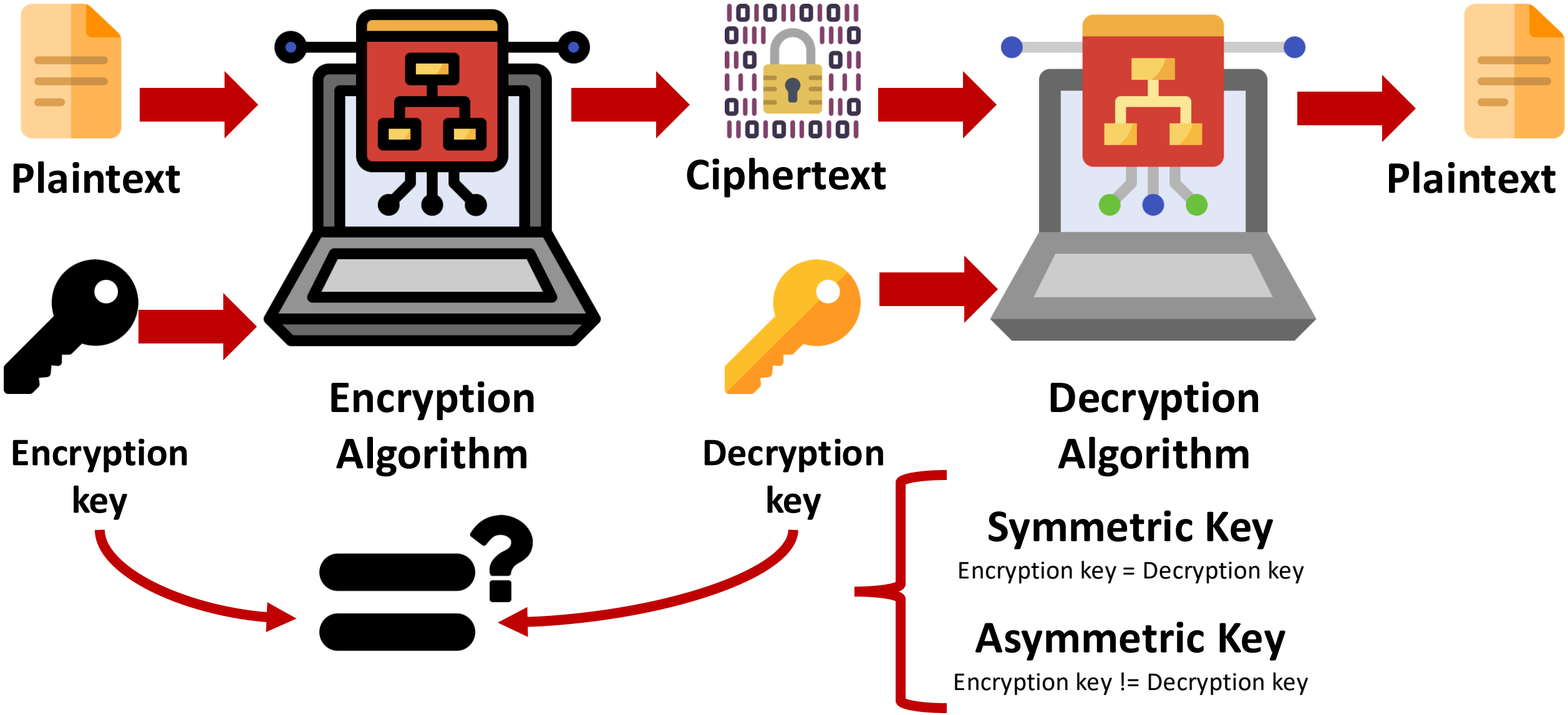
Encryption and Decryption

Stony Brook University



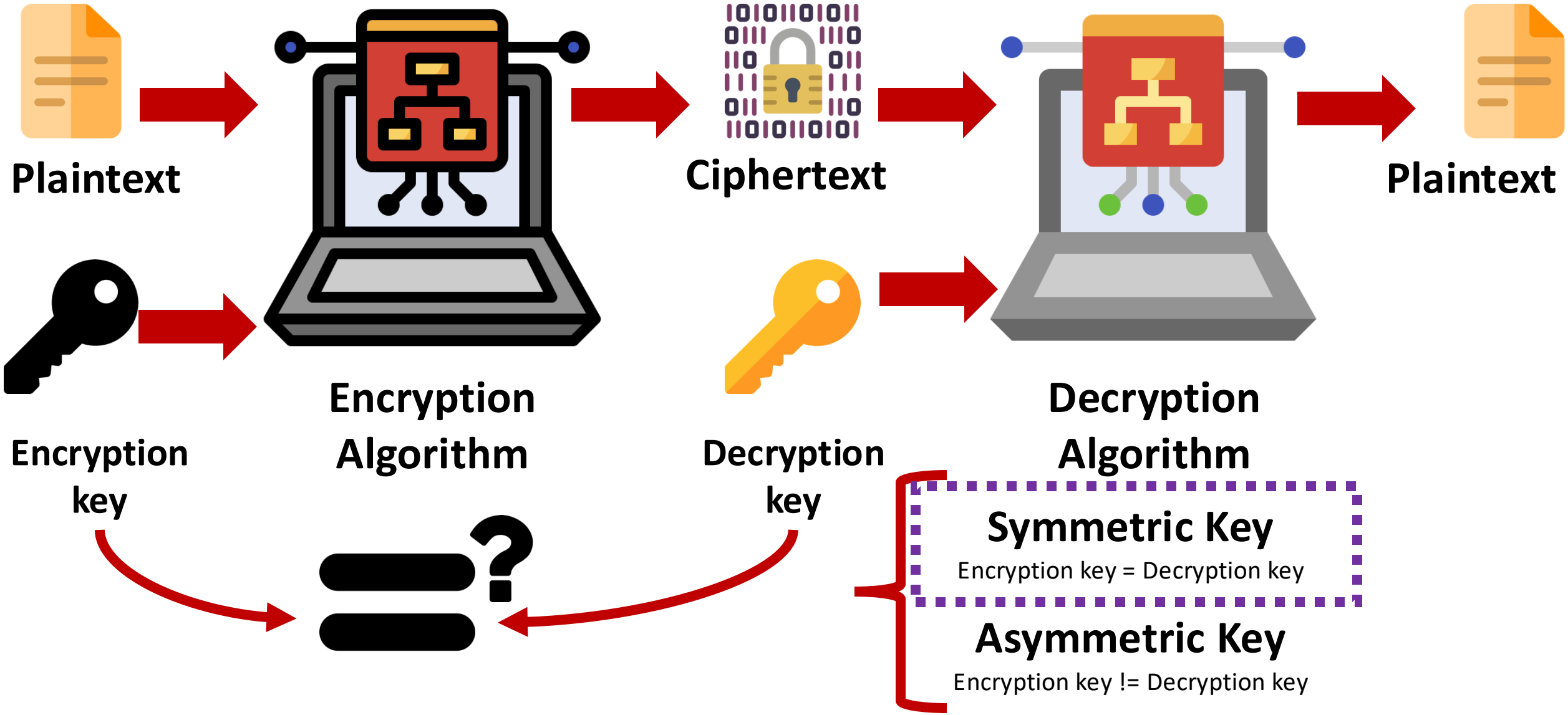
Encryption and Decryption

Stony Brook University



Encryption and Decryption

Stony Brook University



Random One-Time Pad

Stony Brook University

- **Fix the vulnerability of classic ciphers by using very long keys**
- **The key to be used is a random string as long as the message**
- **Encryption is similar to shift ciphers**
- **Invented by Vernam in the 1920s**

Random One-Time Pad

Stony Brook University

- Let $Z_m = \{0,1,2,\ldots,m-1\}$ be the alphabet
- Plaintext space = Ciphertext space = Key space = $(Z_m)^n$
- The key is chosen uniformly randomly
- Plaintext $P = (p_1\ p_2 \ldots p_n)$
- Key $K = (k_1\ k_2 \ldots k_n)$
- Ciphertext $C = (c_1\ c_2 \ldots c_n)$
- $E_K(P) = (p_1+k_1\ p_2+k_2 \ldots p_n+k_n) \bmod m$ [**Encryption**]
- $D_K(C) = (c_1-k_1\ c_2-k_2 \ldots c_n-k_n) \bmod m$ [**Decryption**]

Exclusive OR (⊕)

Stony Brook University

⊕	1	0
1	0	1
0	1	0

- $A \oplus A = 0$
- $A \oplus 1 = \sim A$ (~ denotes negation or NOT)
- $A \oplus 0 = A$
- **$A \oplus A \oplus B = B$**

Binary Version of Random OTP

Stony Brook University

- Let $Z_m = \{0,1\}$ be the alphabet
- Plaintext space = Ciphertext space = Key space = $\{0,1\}^n$
- The key is chosen uniformly randomly
- Plaintext $P = (p_1\ p_2 \ldots p_n)$
- Key $K = (k_1\ k_2 \ldots k_n)$
- Ciphertext $C = (c_1\ c_2 \ldots c_n)$
- $E_K(P) = (p_1 \oplus k_1\ p_2 \oplus k_2 \ \ldots\ p_n \oplus k_n)$ [**Encryption**]
- $D_K(C) = (c_1 \oplus k_1\ c_2 \oplus k_2 \ \ldots\ c_n \oplus k_n)$ [**Decryption**]

Binary Version of Random OTP

Stony Brook University

- Let $Z_m = \{0,1\}$ be the alphabet
- Plaintext space = Ciphertext space = Key space = $\{0,1\}^n$
- The key is chosen uniformly randomly
- Plaintext $P = (p_1\ p_2 \ldots p_n)$
- Key $K = (k_1\ k_2 \ldots k_n)$
- Ciphertext $C = (c_1\ c_2 \ldots c_n)$
- $E_K(P) = (p_1 \oplus k_1\ p_2 \oplus k_2 \ldots p_n \oplus k_n)$ [**Encryption**]
- $D_K(C) = (c_1 \oplus k_1\ c_2 \oplus k_2 \ldots c_n \oplus k_n)$ [**Decryption**]

- $A \oplus A = 0$
- $A \oplus 1 = \sim A$
- $A \oplus 0 = A$
- $\mathbf{A \oplus A \oplus B = B}$

Binary Version of Random OTP

Stony Brook University

- Let $Z_m = \{0,1\}$ be the alphabet
- Plaintext space = Ciphertext space = Key space = $\{0,1\}^n$
- The key is chosen uniformly randomly
- Plaintext $P = (p_1\ p_2 \ldots p_n)$
- Key $K = (k_1\ k_2 \ldots k_n)$
- Ciphertext $C = (c_1\ c_2 \ldots c_n)$
- $E_K(P) = (p_1 \oplus k_1\ p_2 \oplus k_2 \ \ldots\ p_n \oplus k_n)$ [**Encryption**]
- $D_K(C) = (c_1 \oplus k_1\ c_2 \oplus k_2 \ \ldots\ c_n \oplus k_n)$ [**Decryption**]

- $A \oplus A = 0$
- $A \oplus 1 = \sim A$
- $A \oplus 0 = A$
- $\mathbf{A \oplus A \oplus B = B}$

Why $\oplus$? Why not $\wedge$ or $\vee$

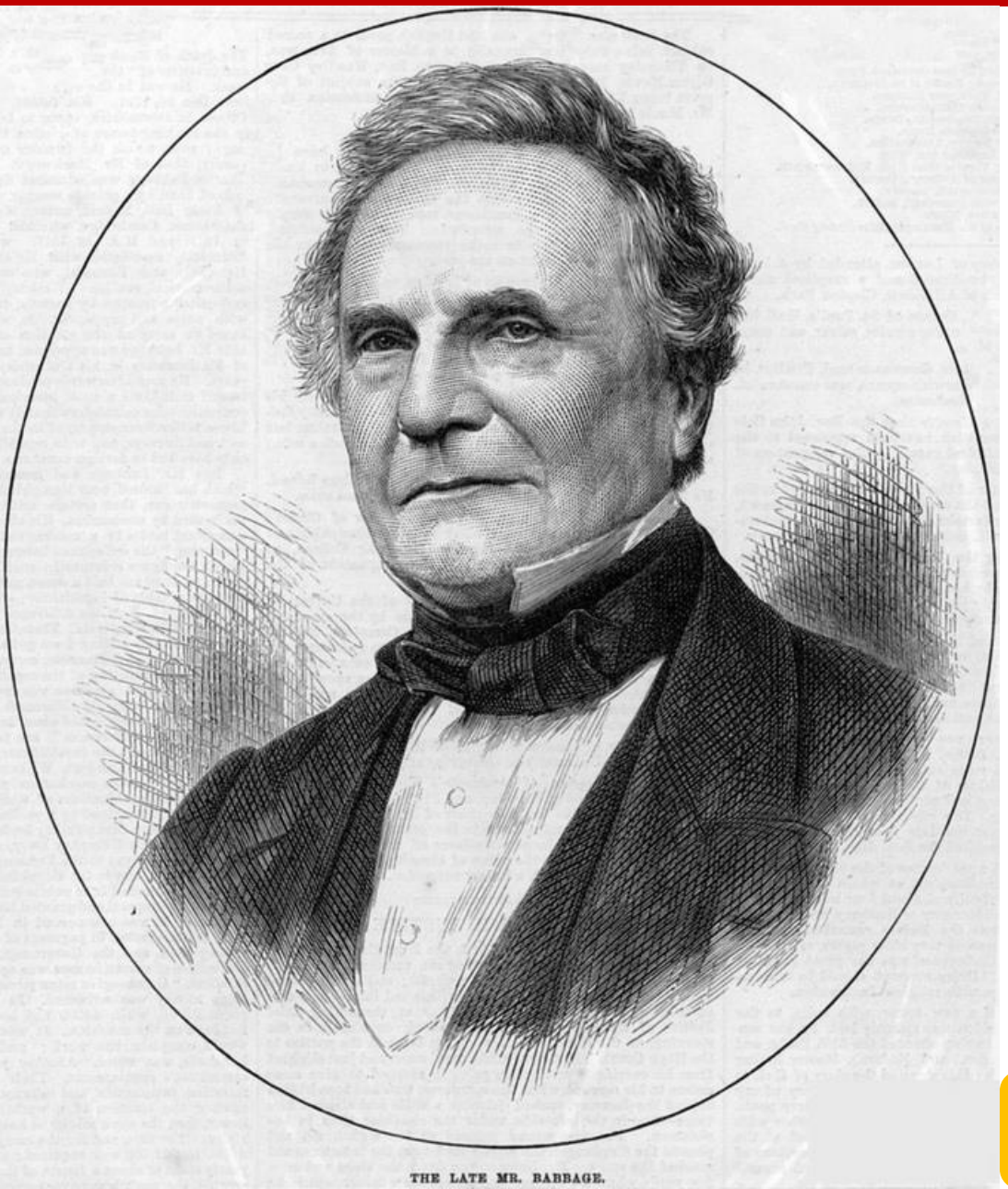


Image credit: https://imgur.com/a/yjhTo

Using Logical AND (∧)

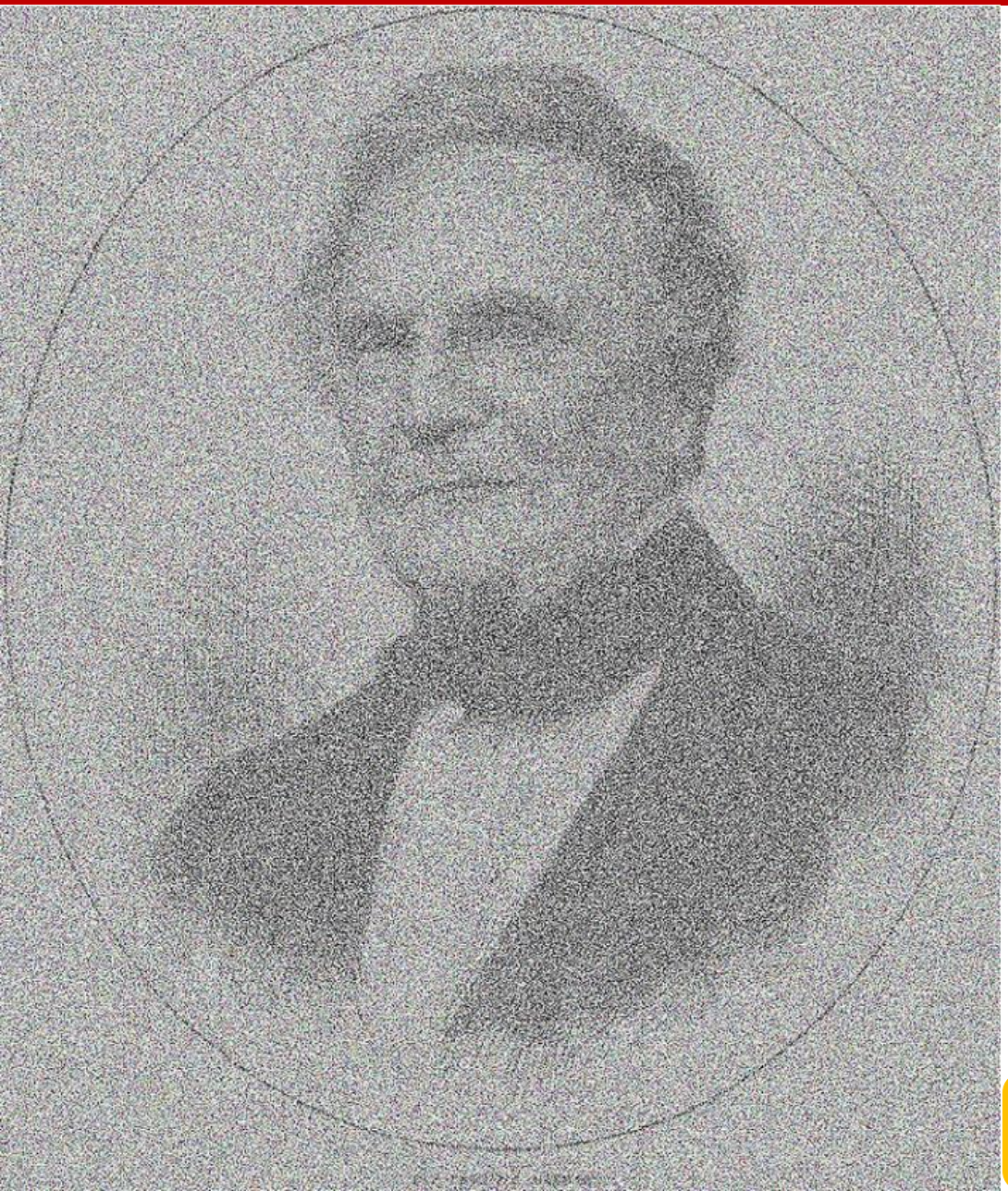
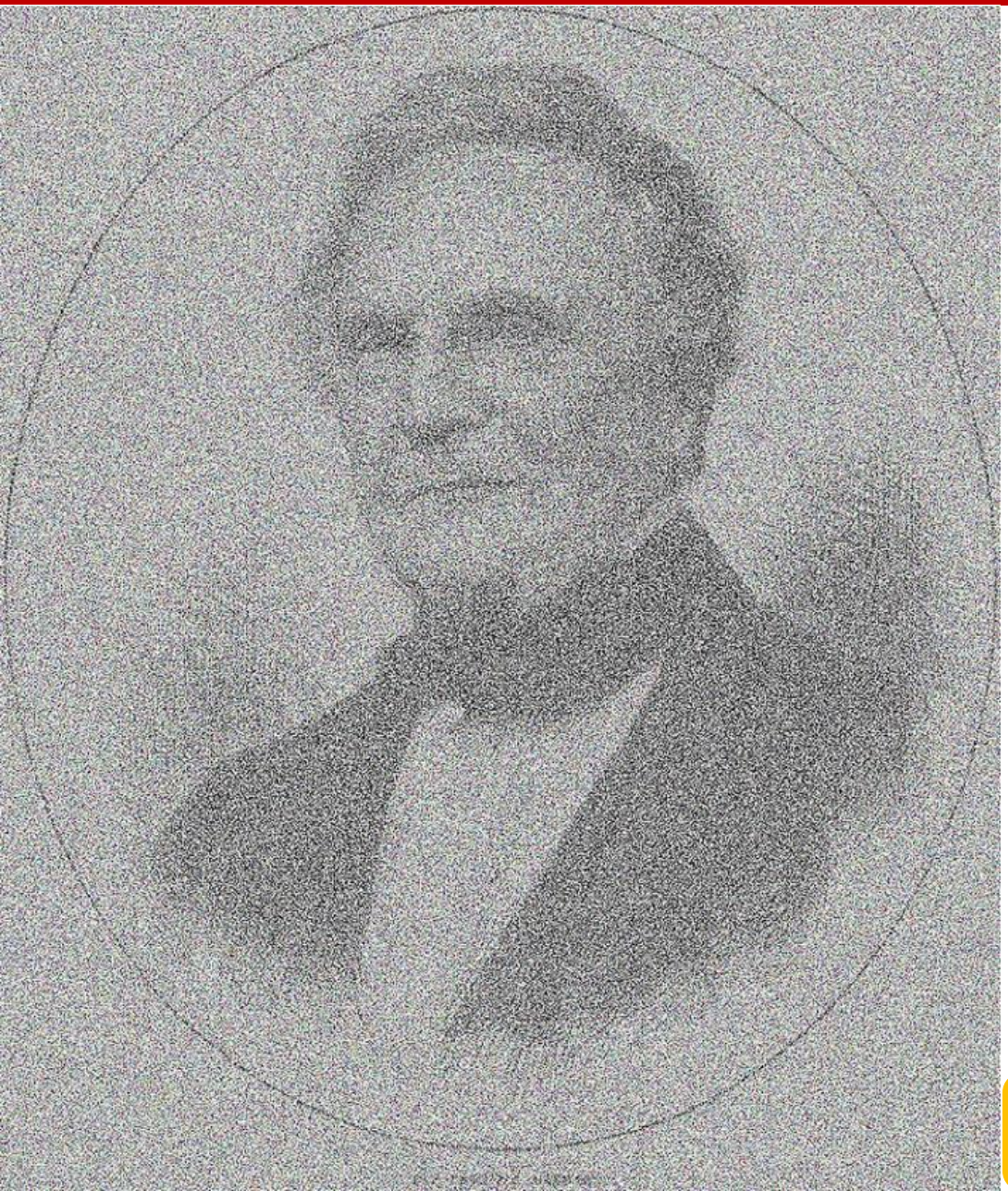


Image credit: https://imgur.com/a/yjhTo

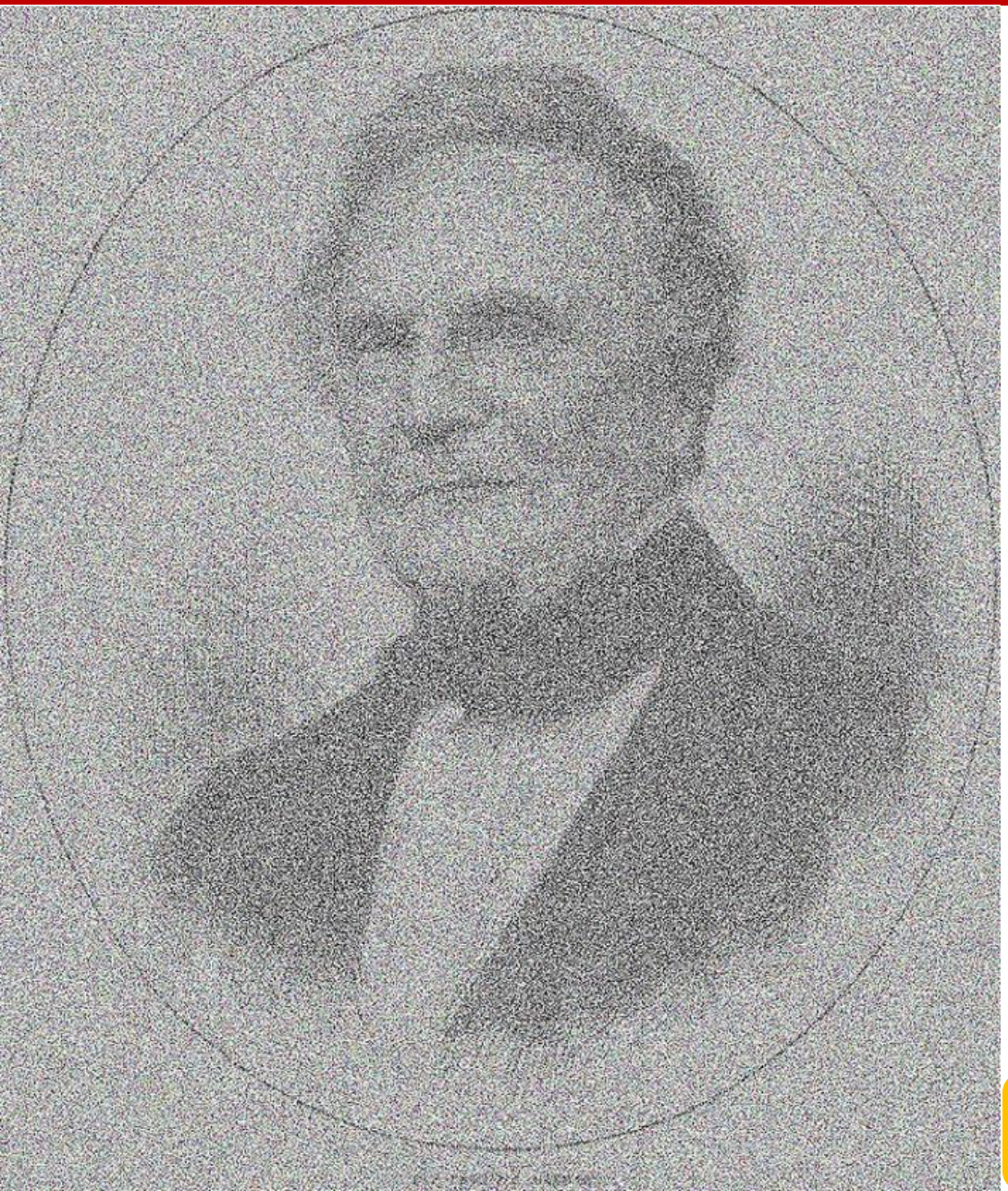
Using Logical AND (∧)



Original Message contains 0

Image credit: https://imgur.com/a/yjhTo

Using Logical AND (∧)



Original Message contains 0

Key contains 1

Image credit: https://imgur.com/a/yjhTo

Using Logical OR (V)

Image credit: https://imgur.com/a/yjhTo

Using Logical OR (V)

Original Message contains 1

Image credit: https://imgur.com/a/yjhTo

Using Logical OR (V)

Original Message contains 1

Key contains 0

Image credit: https://imgur.com/a/yjhTo

Using Exclusive OR($\oplus$)

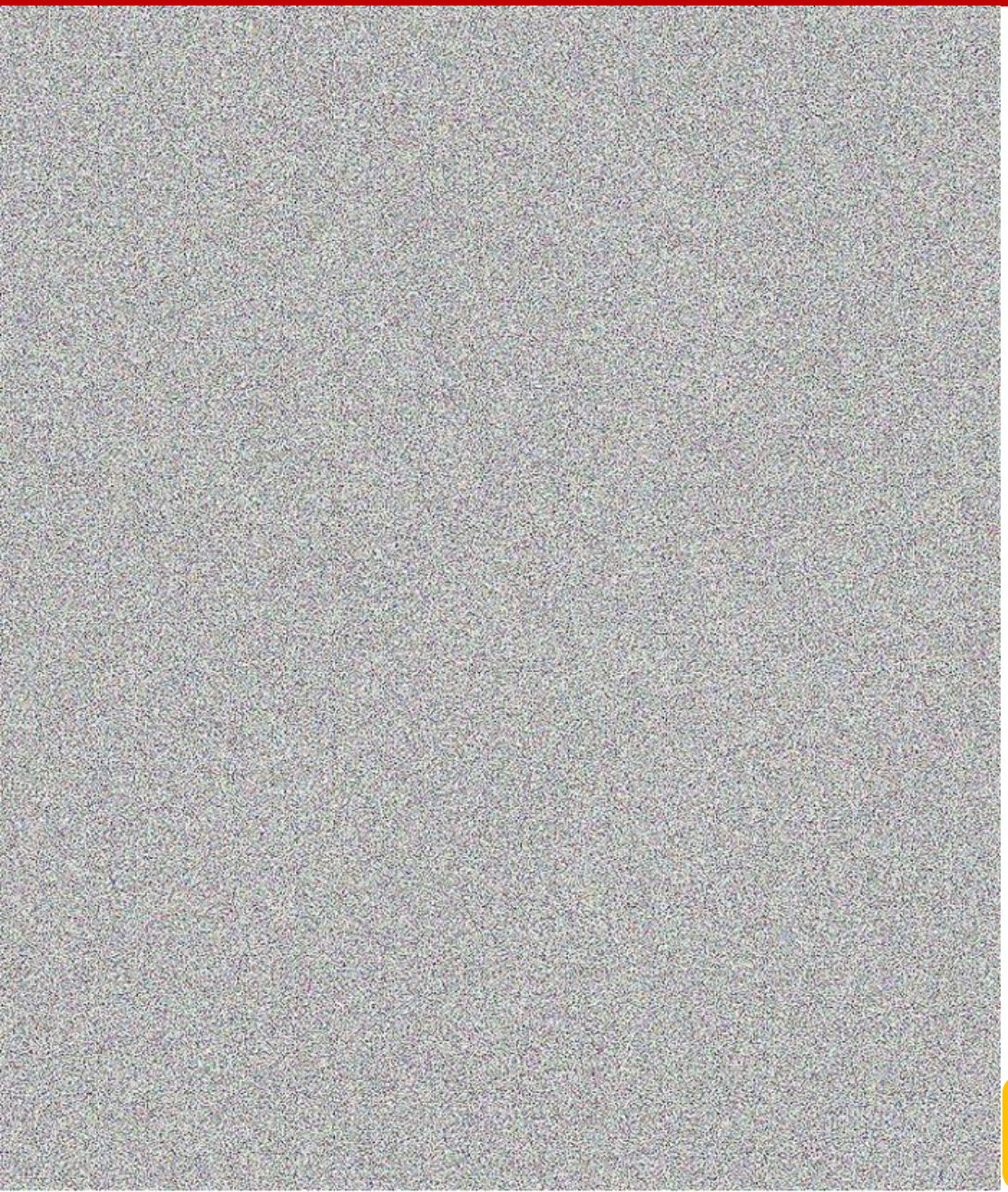


Image credit: https://imgur.com/a/yjhTo

Key Randomness in Random OTP

Stony Brook University

- **Random One-Time Pad uses a very long key**
- **What if the key is not chosen randomly?**
  - **Example:** Texts from a book is used as the key
  - This is not One-Time Pad anymore
  - This can be broken
  - The question is how?

Key Randomness in Random OTP

Stony Brook University

- **Random One-Time Pad uses a very long key**
- **What if the key is not chosen randomly?**
  - **Example:** Texts from a book is used as the key
  - This is not One-Time Pad anymore
  - This can be broken
  - The question is how?

Corollary

The key in One-Time Pad should never be reused

Key Randomness in Random OTP

Stony Brook University

- **Random One-Time Pad uses a very long key**
- **What if the key is not chosen randomly?**
  - **Example:** Texts from a book is used as the key
  - This is not One-Time Pad anymore
  - This can be broken
  - The question is how?

Corollary

The key in One-Time Pad should never be reused

Why?

Usage of Random OTP

Stony Brook University

- **The channel for distributing keys may exist at a different time from when one has messages to send**

- **The channel for distributing keys may have the property that keys can be leaked, but such leakage will be detected**
  - Quantum Cryptography

Adversary Models for Ciphers

Stony Brook University

- The language of the plaintext and the nature of the cipher are assumed to be known to the adversary
- **Ciphertext-only attack**: The adversary only knows a number of ciphertexts
- **Known-plaintext attack**: The adversary knows some pairs of ciphertext and corresponding plaintext
- **Chosen-plaintext attack**: The adversary can choose a number of messages and obtain their ciphertexts
- **Chosen-ciphertext attack**: The adversary can choose a number of ciphertexts and obtain their plaintexts

Adversary Models for Ciphers

Stony Brook University

- The language of the plaintext and the nature of the cipher are assumed to be known to the adversary

Passive

- **Ciphertext-only attack**: The adversary only knows a number of ciphertexts
- **Known-plaintext attack**: The adversary knows some pairs of ciphertext and corresponding plaintext
- **Chosen-plaintext attack**: The adversary can choose a number of messages and obtain their ciphertexts
- **Chosen-ciphertext attack**: The adversary can choose a number of ciphertexts and obtain their plaintexts

Adversary Models for Ciphers

Stony Brook University

- The language of the plaintext and the nature of the cipher are assumed to be known to the adversary

Passive

- **Ciphertext-only attack**: The adversary only knows a number of ciphertexts
- **Known-plaintext attack**: The adversary knows some pairs of ciphertext and corresponding plaintext
- **Chosen-plaintext attack**: The adversary can choose a number of messages and obtain their ciphertexts
- **Chosen-ciphertext attack**: The adversary can choose a number of ciphertexts and obtain their plaintexts

Active

Examples

- **Ciphertext-only attack**:
  - Just sniff the channel between the two parties
- **Known-plaintext attack**:
  - Stock market
  - Quarterly report
  - Known protocol ("Hello" message)
- **Chosen-plaintext attack**:
  - DRM, WWII
- **Chosen-ciphertext attack**:
  - Unauthenticated channel

Which attacks to defend against?

Stony Brook University

- It is very tempting to always design a cryptosystem that is secure against the strongest attacks
- Cryptosystems that protect against the strongest attacks are often less efficient
- While designing a cryptosystem, to decide which attacks to protect against, one has to consider the application at hand
- For the application in question, if only the weaker attacks make sense, then cryptosystems should be designed accordingly

The Open Design Security Principle

Stony Brook University

- **Kerckhoffs's principle**:
  - A cryptosystem should be secure even if everything about the system, except the key, is public knowledge
- **Shannon's maxim**:
  - "The enemy knows the system"

The Open Design Security Principle

Stony Brook University

- **Kerckhoffs's principle**:
  - A cryptosystem should be secure even if everything about the system, except the key, is public knowledge
- **Shannon's maxim**:
  - "The enemy knows the system"

Lesson

Security by obscurity does not work.

The Open Design Security Principle

Stony Brook University

- **Kerckhoffs's principle**:
  - A cryptosystem should be secure even if everything about the system, except the key, is public knowledge
- **Shannon's maxim**:
  - "The enemy knows the system"

Lesson

Security by obscurity does not work.

The only secret the adversary is assumed to not know is the encryption key

Modern Symmetric Ciphers and their Security

Notation for Symmetric Ciphers

Stony Brook University

- A symmetric-key encryption scheme is comprised of the following three algorithms:
  - **Gen** (the key generation algorithm)
    - This algorithm must be probabilistic/randomized
    - **Input**: a security parameter λ
    - **Output**: a symmetric key K
  - **Enc** (the encryption algorithm)
    - **Input**: a key K and a plaintext m
    - **Output**: ciphertext $c := Enc_k(m)$
  - **Dec** (the decryption algorithm)
    - **Input**: a key K and a ciphertext c
    - **Output**: plaintext $m := Dec_k(c)$

Notation for Symmetric Ciphers

Stony Brook University

- A symmetric-key encryption scheme is comprised of the following three algorithms:
  - **Gen** (the key generation algorithm)
    - This algorithm must be probabilistic/randomized
    - **Input**: a security parameter λ
    - **Output**: a symmetric key K
  - **Enc** (the encryption algorithm)
    - **Input**: a key K and a plaintext m
    - **Output**: ciphertext c := $Enc_k(m)$
  - **Dec** (the decryption algorithm)
    - **Input**: a key K and a ciphertext c

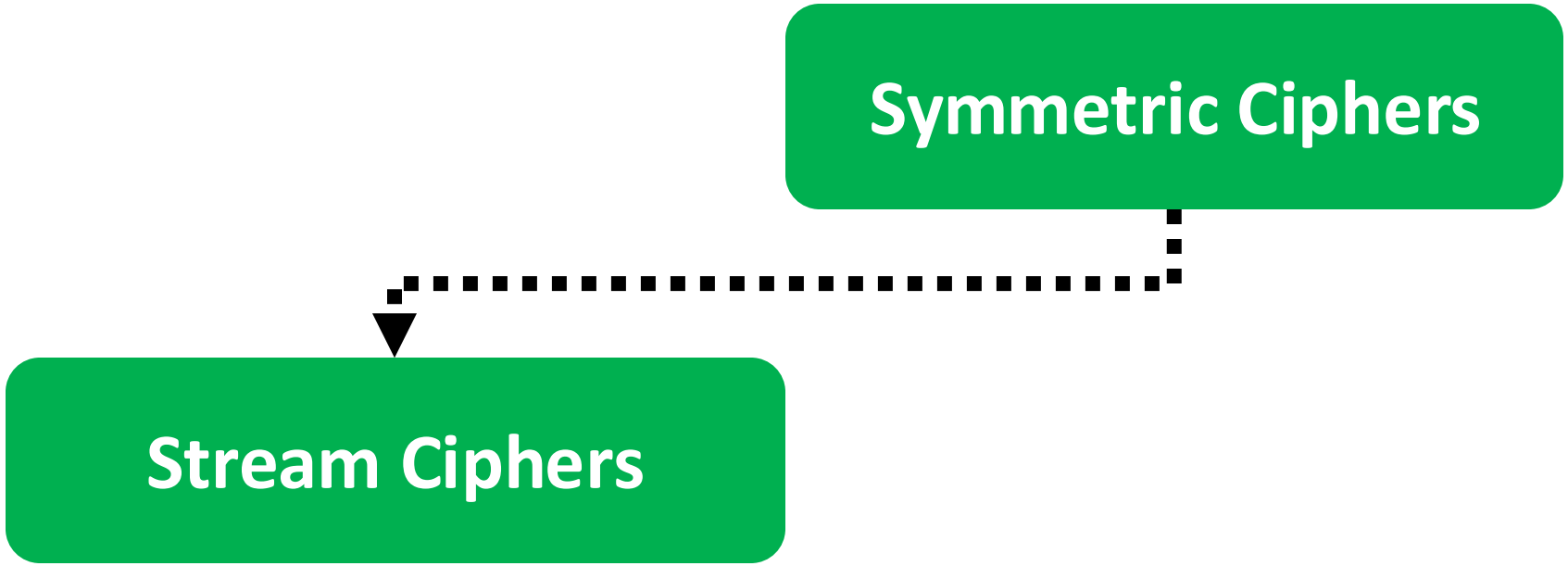
$$\forall k. \forall m: Deck\big(Enc_k(m)\big) = m$$

Modern Symmetric Ciphers

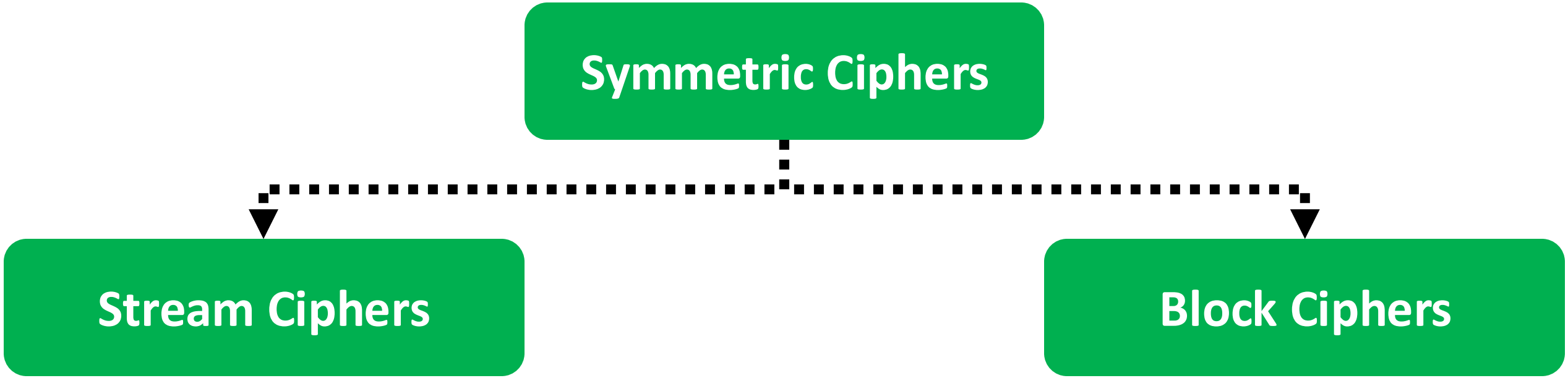
Modern Symmetric Ciphers

Symmetric Ciphers

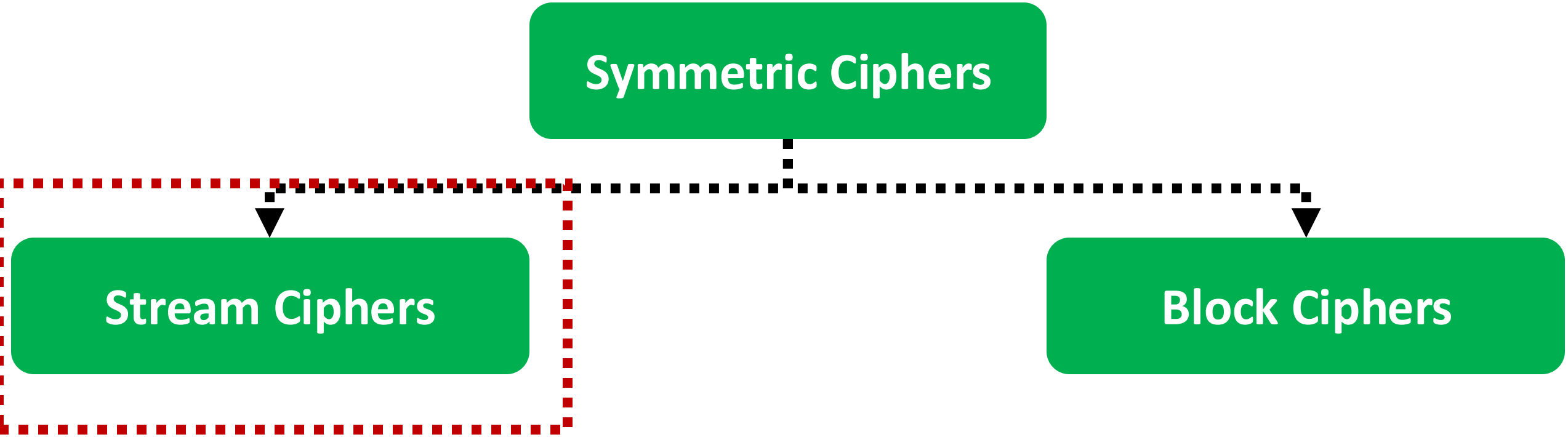
Modern Symmetric Ciphers



Modern Symmetric Ciphers



Modern Symmetric Ciphers



Stream Ciphers

- Modern stream ciphers approximate random one-time pad
- Recall, in random one-time pad, the key is a **random** string of length at least the same as the message
- **Stream ciphers**:
  - **Insight**: replace "*random*" by "*pseudo-random*"
  - Use pseudo-random number generators
  - **PRNG: $\{0,1\}^s \rightarrow \{0,1\}^n$**
    - Expand a short (e.g., 128-bit) random seed into a long (typically unbounded) string that "looks random"
  - Secret symmetric key is the seed
  - Basic encryption method: $\mathbf{E_K(M) = M \oplus PRNG(K)}$

RC4 Stream Cipher

Stony Brook University

- A proprietary cipher owned by RSA, designed by Ron Rivest in 1987
- Became public in 1994
- Simple and effective design
- Variable key size (typically 40 to 256 bits)
- Output length unbounded
- Used to widely applied (web SSL/TLS, wireless WEP)
- **Extensively studied but not quiet a completely secure PRNG**
  - The first part of output is biased when used in a stream cipher
  - Should use **RC4-Drop[n]**
  - This drops the first n bytes before using the output
  - Conservatively, set **n = 3072**

Pseudorandom Number Generators

Stony Brook University

- Security of stream ciphers fully rely on the underlying PRNG to be **cryptographically secure or strong**
- Useful for cryptography, simulation, randomized algorithm
- The same seed always gives the same output stream
- Simulation requires uniformly distributed sequences
- Cryptographically secure PRNG requires unpredictable sequences
  - **Security of PRNGs**: Secure PRNGs should satisfy the "**next-bit test**"
  - **Next-bit Test**: Given consecutive sequence of bits output (but not the seed), the next bit should be hard to predict
- ***Some PRNGs are weak***: knowing output sequence of sufficient length, can recover key
  - Do not use such PRNGs for cryptographic purposes

Stream Cipher Security

Stony Brook University

- Under known plaintext, chosen plaintext, or chosen ciphertext, the adversary knows the key stream (i.e., PRNG(key))
- Security of stream ciphers mainly rely on the strength of the underlying PRNG
- **PRNG must be "unpredictable"**
  - An adversary cannot computationally distinguish input from a complete random number generator and a PRNG
  - Precise definition can be found in the "Modern Cryptography" book (I will share the necessary portion)
- **If the same key is used twice, then it is easy to break**
  - This is a fundamental weakness of stream ciphers
  - It exists even if the underlying PRNG used in the stream cipher satisfies the next-bit test

Stream Cipher Security

Stony Brook University

- Under known plaintext, chosen plaintext, or chosen ciphertext, the adversary knows the key stream (i.e., PRNG(key))
- Security of stream ciphers mainly rely on the strength of the underlying PRNG
- **PRNG must be "unpredictable"**
  - An adversary cannot computationally distinguish input from a complete random number generator and a PRNG
  - Precise definition can be found in the "Modern Cryptography" book (I will share the necessary portion)
- **If the same key is used twice, then it is easy to break**
  - This is a fundamental weakness of stream ciphers
  - It exists even if the underlying PRNG used in the stream cipher satisfies the next-bit test

$$E_K(M) = M \oplus PRNG(K)$$

How do I use one symmetric key to encrypt multiple messages?

Stream Cipher in Practice

Stony Brook University

- In practice, one key is used to encrypt many messages
- **Example**: wireless communication
- **Solution**: Use an initialization vector IV (sometimes, called nonce)
  - $E_K(M) := [IV, M \oplus PRNG(K \,||\, IV)]$ {|| refers to concatenation}
- Expectations from the IV
  - IV is sent in clear to the receiver
  - IV needs integrity protection but not confidentiality
  - IV ensures that key streams do not repeat, but does not increase the cost of brute-force attacks
  - Without key, knowing IV will not let the attack decrypt the ciphertext
- One has to ensure that the IV never repeats! Why? How?

Deterministic and Randomized

Stony Brook University

- Encryption can be randomized
  - Same message, same key, running the same algorithm twice results in two different ciphertexts
  - $Enc_k(m) = (r, PRNG(k \mid\mid r) \oplus m)$ – the ciphertext includes two parts, a randomly generated r, and a second part
- Decryption is always deterministic in the sense that
  - For the same ciphertext and the same key, running the decryption algorithm twice always results in the same plaintext
- Each key induces a one-to-many mapping from plaintext space to the ciphertext space
- **Corollary**: Ciphertext space must be equal to or larger than the plaintext space

Deterministic Encryption

Stony Brook University

- Deterministic encryptions are bad and insecure in most of the cases
  - This will be formally explained later

- One can use frequency analysis if they were to know the underlying distribution of the plaintext space

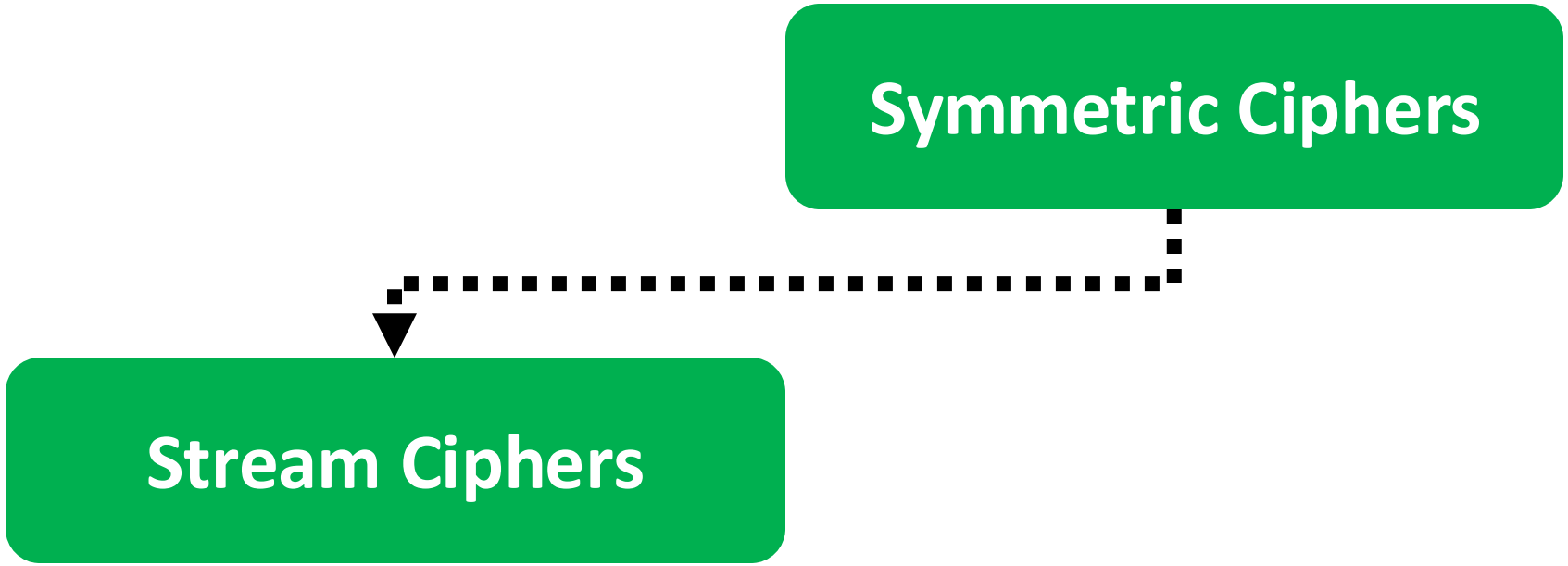
- An example paper of such an attack on deterministic encryption:
  - Inference attacks on Property-preserving Encrypted Databases
  - Published in ACM CCS 2015
  - The paper can be found here: https://cs.brown.edu/~seny/pubs/edb.pdf

Modern Symmetric Ciphers

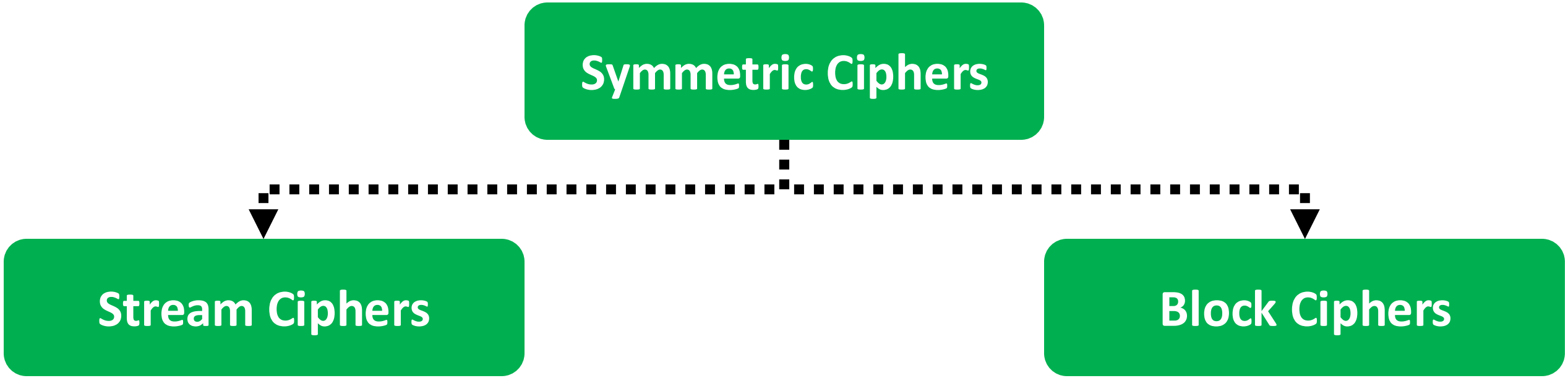
Modern Symmetric Ciphers

Symmetric Ciphers

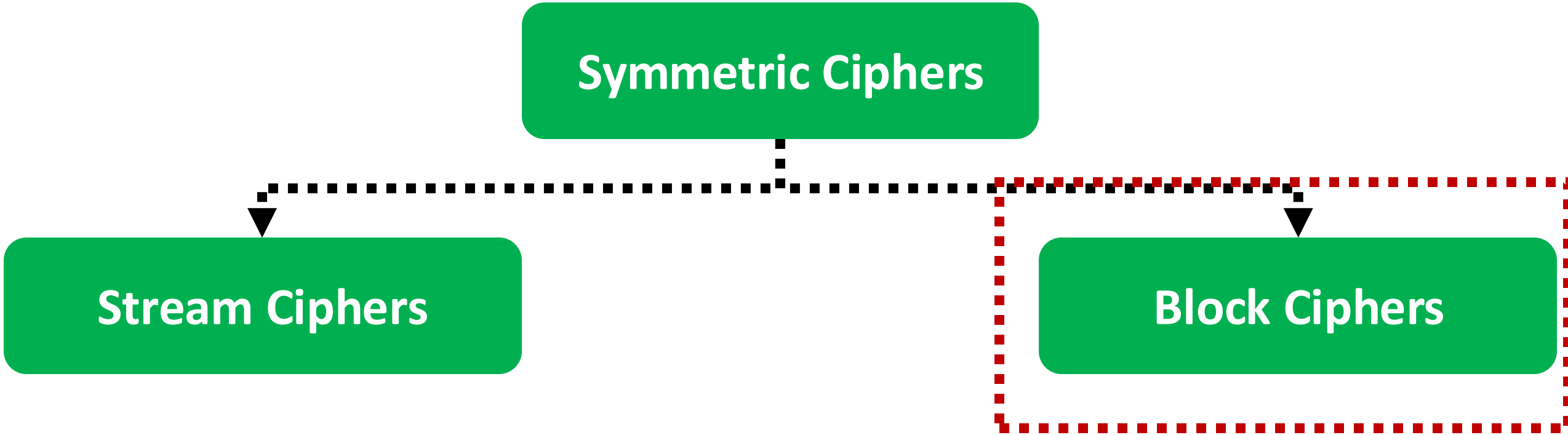
Modern Symmetric Ciphers



Modern Symmetric Ciphers



Modern Symmetric Ciphers



Block Ciphers

Stony Brook University

- **A n-bit plaintext is encrypted to an n-bit ciphertext**
- P : $\{0,1\}^n$
- C : $\{0,1\}^n$
- K : $\{0,1\}^n$
- **Enc: K x P→ C**
  - $Enc_k(.)$ can be viewed as a permutation of $\{0,1\}^n$
- **Dec: K x C→ P**
  - $Dec_k(.)$ can be viewed as $Enc_k^{-1}(.)$
- Block size = n
- Key size = s

Data Encryption Standard (DES)

Stony Brook University

- Designed by IBM, with modifications proposed by NSA
- US national standard from 1977 to 2001
- Block size 64 bits
- Key size **56 bits**
- Has 16 rounds
- Designed mostly for hardware implementations
  - Software implementations are slow
- Considered insecure now
  - Vulnerable to brute-force attacks
- **Triple DES:**
  - $E_{K3}D_{K2}E_{k1}(M)$ has 112-bit strength, but slow

Advanced Encryption Standard (AES)

- From 1999, AES replaced DES as the standard for block ciphers
- Aka Rijndael (invented by Joan Daemen and Vincent Rijmen)
- Designed to be efficient in both hardware and software across a variety of platforms
- Block size: **128 bits**
- Variable key size: **128, 192, or 256 bits**
- **No known exploitable algorithmic weaknesses**
- Implementation may be vulnerable to timing attacks (largely due to CPU's architecture of using caches)
- Intel now has AES-NI, CPU-based implementation for AES
  - Timing-based side channel attacks are no longer an issue

Encryption Modes

- *A block cipher encrypts only one block of message*
  - In case of AES, the block size is 128 bits
- **What if the message being encrypted is longer than the block size?**
- Need a way to extend "block ciphers" to encrypt an arbitrarily long message
- We want to ensure that if the underlying block cipher is secure, then the encryption mode is secure
- The main aim is to provide **semantic security** assuming the underlying block ciphers are strong
  - Will introduce "semantic security" in a bit

Encryption Modes

Stony Brook University

- We are going to learn about encryption modes of AES
- Three modes will be discussed
  - Electronic Code Book (ECB)
  - Cipher Block Chaining (CBC)
  - Counter Mode (CTR)
- There are many other modes that I do not discuss here
- See the following for more details: https://en.wikipedia.org/wiki/Block_cipher_mode_of_operation

ECB

Stony Brook University

- The easiest and the most intuitive one out of the different modes of AES
- Recall, AES encrypts one block of message only
- Divide up the message to be encrypted into 128-bit blocks (pad the message when the message length is not a multiple of 128)
- Each block is then encrypted separately
- Assume there are **s** number of blocks in the message
- **Encryption:** $\forall 0 \leq i < s$: $C_i = E_K(P_i)$
- **Decryption:** $\forall 0 \leq i < s$: $P_i = D_K(C_i)$

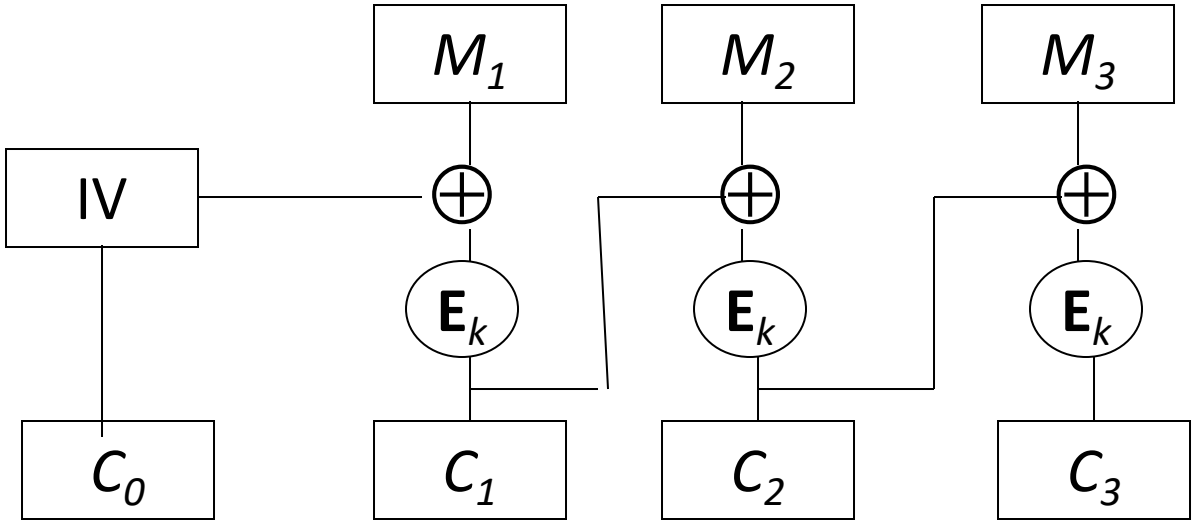
ECB

Stony Brook University

- **ECB is a deterministic encryption scheme**
- The same plaintext data block results in the same ciphertext block
- Reveals patterns of data when a data block repeats
- When the same key is used, the same message is encrypted in the same way
- **Usage:** Not recommended to encrypt more than one block of data
- **Zoom** used it before : https://medium.com/asecuritysite-when-bob-met-alice/zoom-finally-takes-encryption-seriously-and-goes-all-gcm-2e1203a7274b

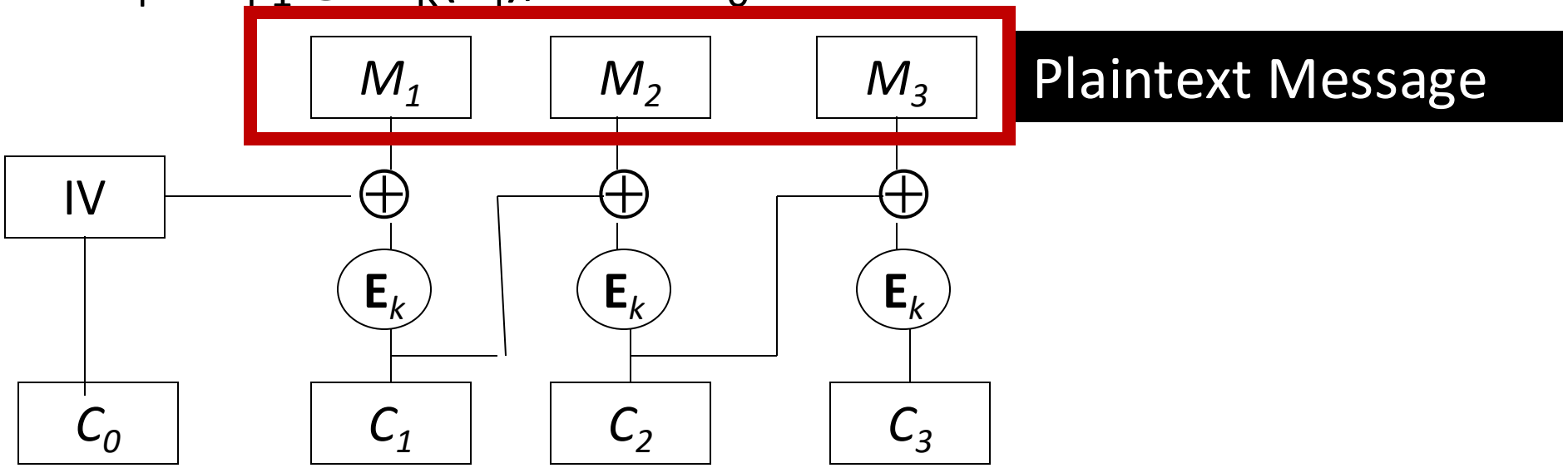
CBC

- Cipher Block Chaining (CBC)
- Uses a random IV
- Next input depends upon previous output
  - **Encryption**: $C_i = E_K(M_i \oplus C_{i-1})$ with $C_0 = IV$
  - **Decryption**: $M_i = C_{i-1} \oplus D_K(C_i)$, with $C_0 = IV$



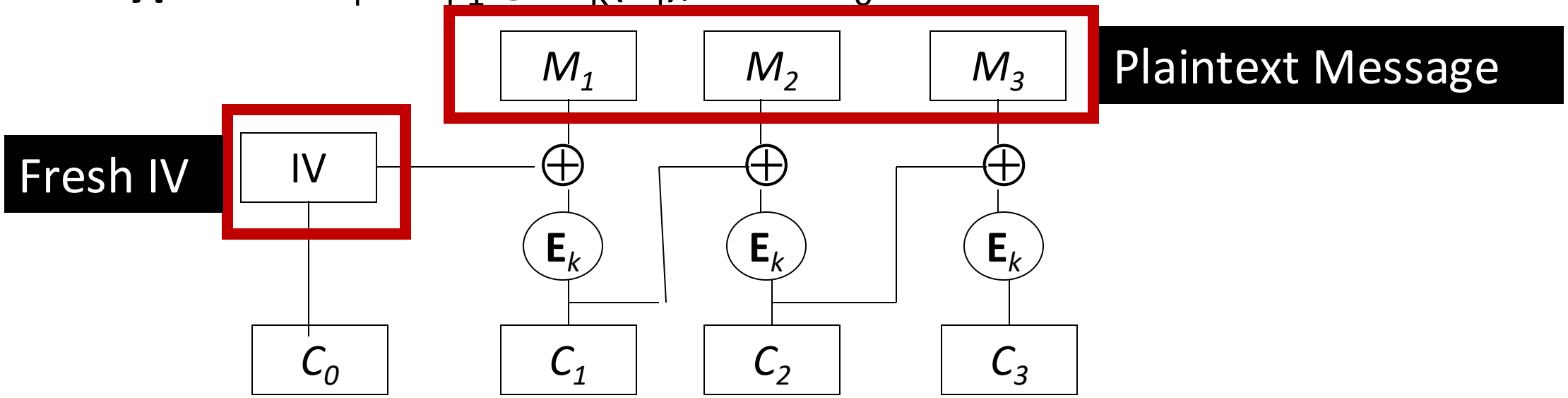
CBC

- Cipher Block Chaining (CBC)
- Uses a random IV
- Next input depends upon previous output
  - **Encryption**: $C_i = E_K(M_i \oplus C_{i-1})$ with $C_0 = IV$
  - **Decryption**: $M_i = C_{i-1} \oplus D_K(C_i)$, with $C_0 = IV$



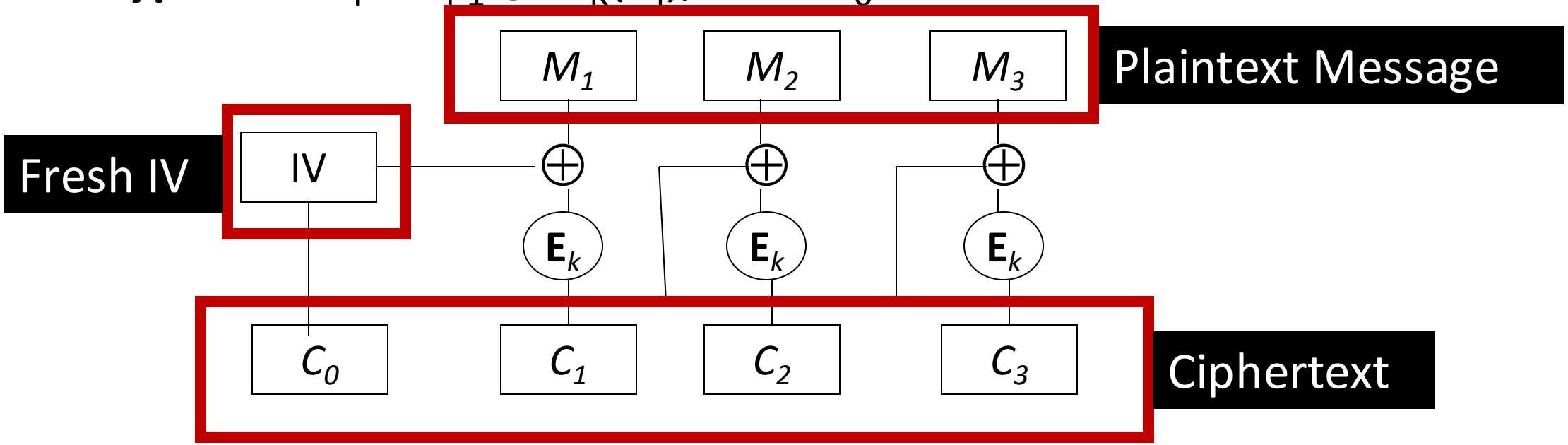
CBC

- Cipher Block Chaining (CBC)
- Uses a random IV
- Next input depends upon previous output
  - **Encryption**: $C_i = E_K(M_i \oplus C_{i-1})$ with $C_0 = IV$
  - **Decryption**: $M_i = C_{i-1} \oplus D_K(C_i)$, with $C_0 = IV$



CBC

- Cipher Block Chaining (CBC)
- Uses a random IV
- Next input depends upon previous output
  - **Encryption**: $C_i = E_K(M_i \oplus C_{i-1})$ with $C_0 = IV$
  - **Decryption**: $M_i = C_{i-1} \oplus D_K(C_i)$, with $C_0 = IV$

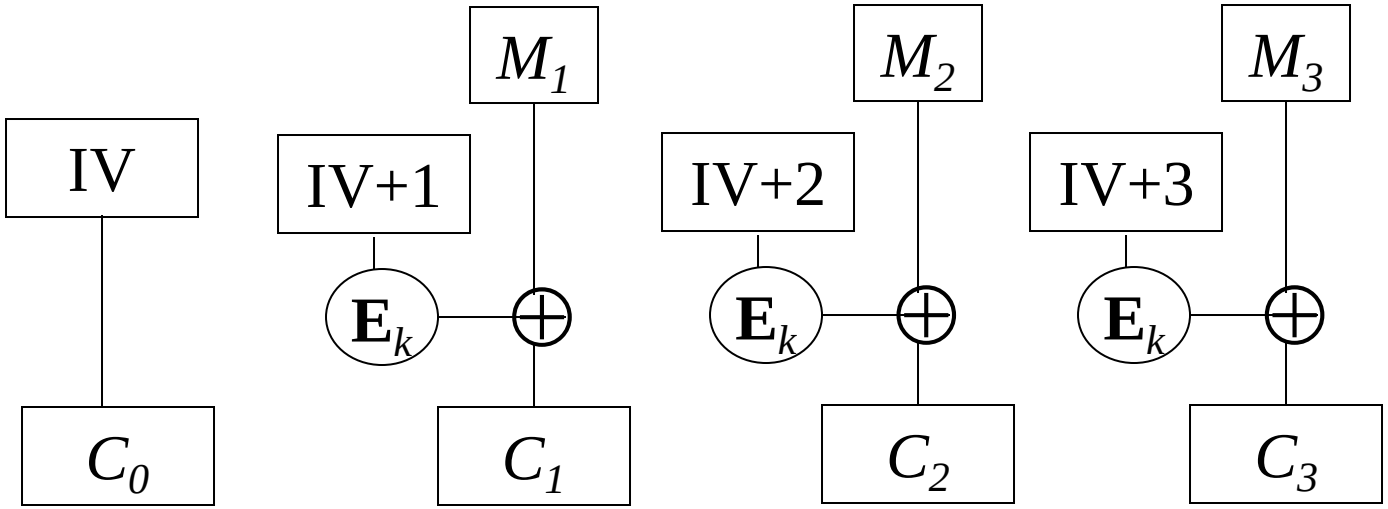


CBC

- **Randomized encryption**: *Repeated text gets mapped to different encrypted data*
  - IV must be randomly chosen to get this benefit
- Each ciphertext block depends on all preceding plaintext blocks
- **Usage**:
  - IV must be random, needs integrity protection but does not need confidentiality
  - The IV is not secret – it is part of the ciphertext
  - The adversary cannot control IV

CTR

- Counter Mode (CTR) – Defines a stream cipher using a block cipher
  - Uses a random IV
  - **Encryption**: $C_i = M_i \oplus E_K(IV+i)$ with $C_0 = IV$
  - **Decryption**: $M_i = C_i \oplus E_K(IV+i)$ with $C_0 = IV$



CTR

- Gives a stream cipher from a block cipher
- **Randomized encryption**: *Repeated text gets mapped to different encrypted data*
  - IV or counter must be randomly chosen to get this benefit
- **Random access**:
  - Encryption and decryption of a block can be done in random order
  - This is very useful for hard-disk encryption
  - When one block changes, re-encryption only needs to encrypt that block. In case of CBC, all later blocks also need to re-encrypted

So far

- **Stream cipher:**
  - **RC4 (with new IV for each message)**
- **Block Cipher:**
  - **AES:** The de-facto standard
  - **DES:** Broken and slow
- **Block cipher modes:**
  - **AES + ECB:** Should be used only in restricted settings
  - **AES + CBC:** Shouldn't be used without integrity
  - **AES + CTR:** Allows random access

So far

Stony Brook University

- **Stream cipher:**
  - **RC4 (with new IV for each message)**
- **Block Cipher:**
  - **AES:** The de-facto standard
  - **DES:** Broken and slow
- **Block cipher modes:**
  - **AES + ECB:** Should be used only in restricted settings
  - **AES + CBC:** Shouldn't be used without integrity
  - **AES + CTR:** Allows random access

Are they secure?

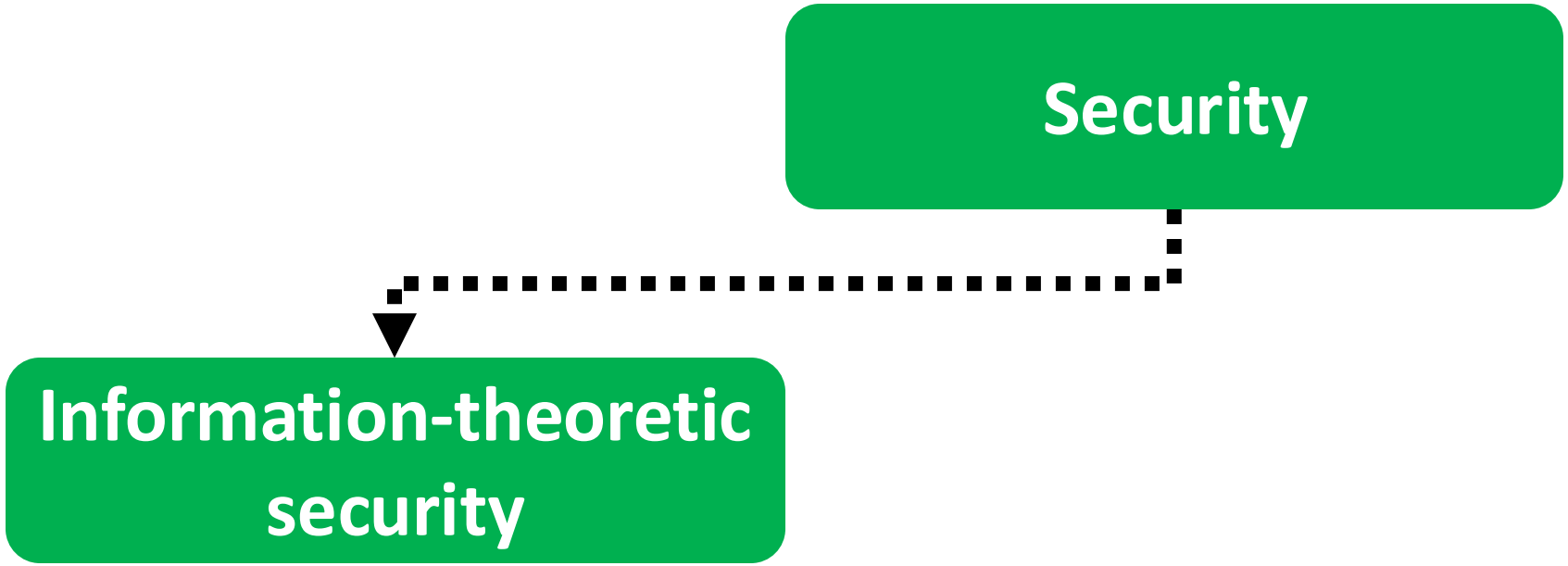
Security Definition

Security Definition

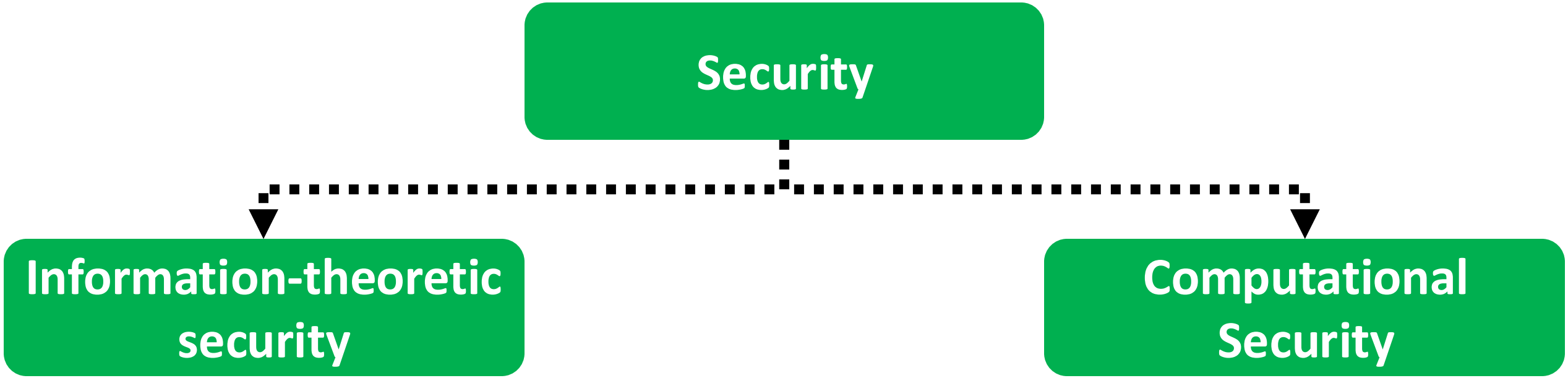
Stony Brook University

Security

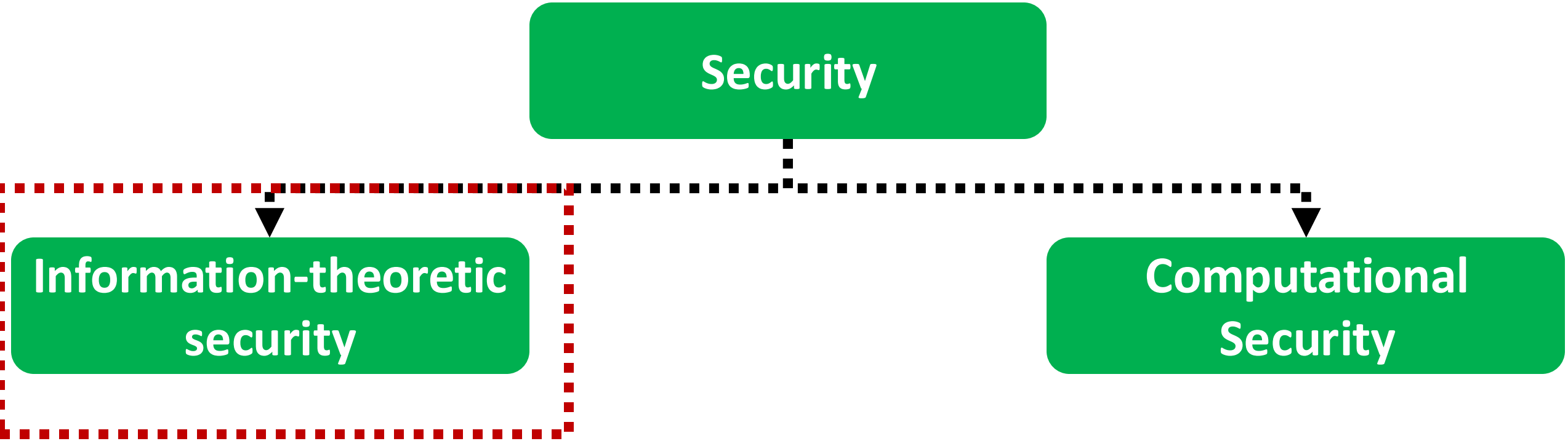
Security Definition



Security Definition



Security Definition



Information-theoretic Security

Stony Brook University

- Perfect secrecy = Shannon (Information-theoretic) Security
- Basic idea: Ciphertext should reveal no "information" about plaintext
- Intuition: Ciphertext should be independent from the plaintext

$\forall$ message m, $\forall$ ciphertext c

$$\Pr[\mathbf{PT}=m \wedge \mathbf{CT}=c] = \Pr[\mathbf{PT}=m]\ \Pr[\mathbf{CT}=c]$$

Or, equivalently

$\forall$ message m1, m2, $\forall$ ciphertext c

$$\Pr[\mathbf{CT}=c \mid \mathbf{PT}=m1] = \Pr[\mathbf{CT}=c \mid PT=m2]$$

Example

- Consider an example of encrypting the result of a 6-side dice (1 to 6).
  - **Method 1:** randomly generate K=[1..6], ciphertext is result + K.
    - What is plaintext distribution?
    - After seeing that the ciphertext is 3, what could be the plaintext?
    - After seeing that the ciphertext is 12, what could be the plaintext?
  - **Method 2:** randomly generate K=[1..6], ciphertext is (result + K) mod 6.
    - Same questions.
    - Can one do a brute-force attack?

Perfect Secrecy

Stony Brook University

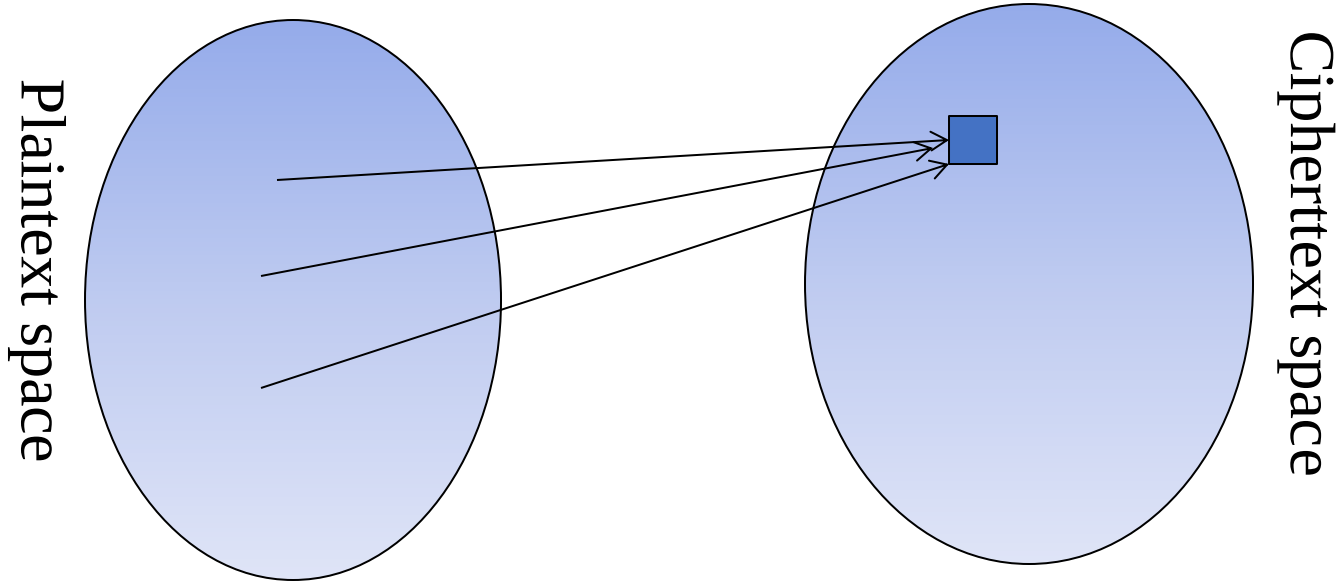
- **Fact:** When keys are uniformly chosen in a cipher, the cipher has perfect secrecy *iff* the number of keys encrypting M to C is the same for any (M,C)
  - This implies the following:
    $\forall c \forall m_1 \forall m_2 \Pr[\mathbf{CT}=c \mid \mathbf{PT}=m_1] = \Pr[\mathbf{CT}=c \mid \mathbf{PT}=m_2]$

- One-time pad has perfect secrecy when limited to messages over the same length (Proof?)

Bad News

- **Question:** OTP requires key as long as messages, is this an inherent requirement for achieving perfect secrecy?
- **Answer.** Yes. Perfect secrecy implies that key-length ≥ msg-length

Proof: (see https://math.umd.edu/~lcw/OneTimePad.pdf**)**



- **Implication:** Perfect secrecy difficult to achieve in practice

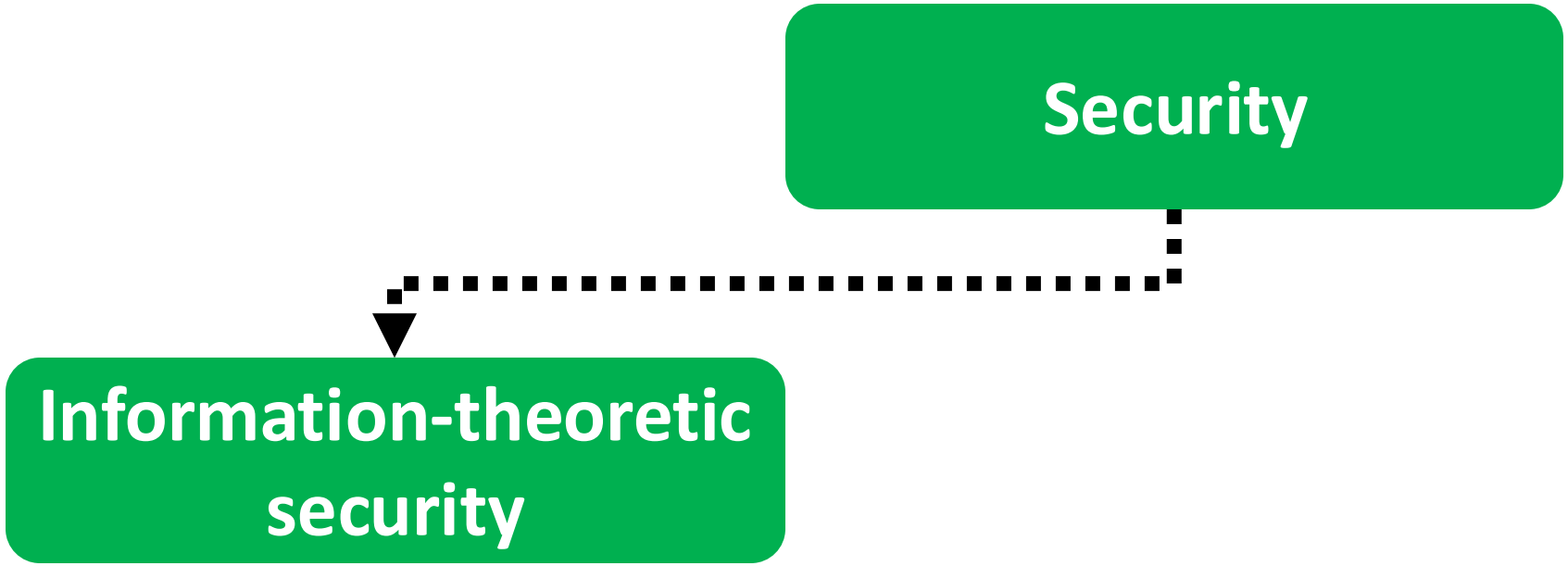
Security Definition

Security Definition

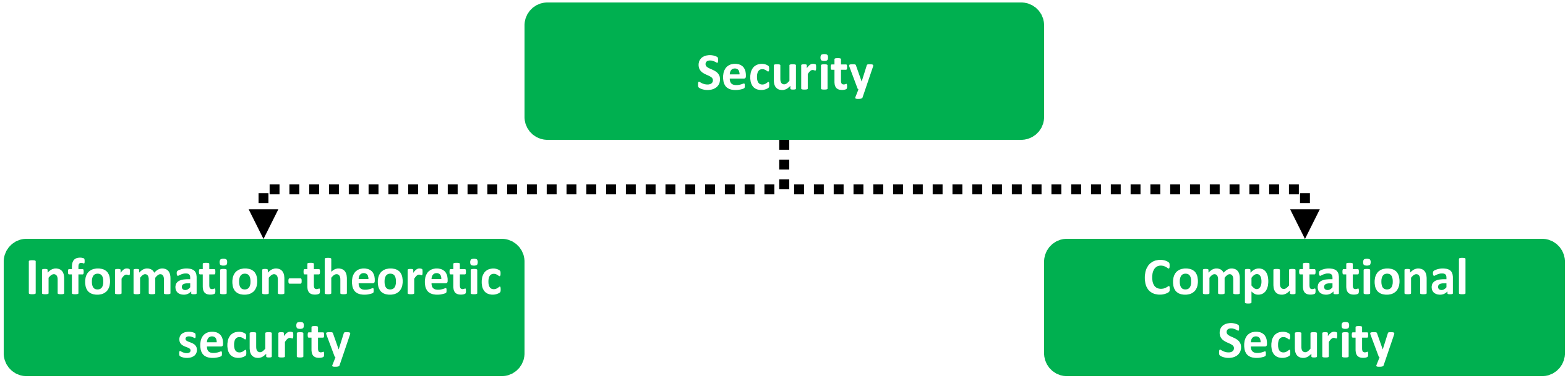
Stony Brook University

Security

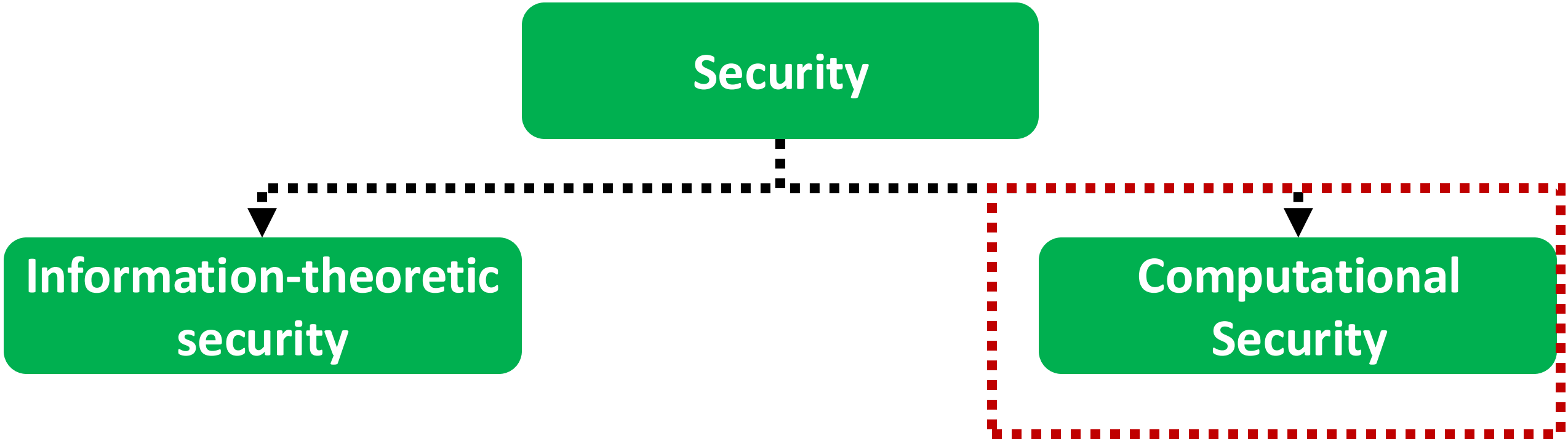
Security Definition



Security Definition



Security Definition



Computational Security

Stony Brook University

- Perfect secrecy is too difficult to achieve in practice

- Computational security uses the following two relaxations
- **Relaxation 1**: *Security is preserved only against efficient (computationally-bounded) adversaries*
  - Adversary can only run in feasible amount of time

- **Relaxation 2**: *Adversaries can potentially succeed with some very small probability (that we can ignore the case it actually happens)*

Computational Security

Stony Brook University

- Perfect secrecy is too difficult to achieve in practice

- Computational security uses the following two relaxations
- **Relaxation 1**: *Security is preserved only against efficient (computationally-bounded) adversaries*
  - Adversary can only run in feasible amount of time

- **Relaxation 2**: *Adversaries can potentially succeed with some very small probability (that we can ignore the case it actually*

Let's try to develop a potential definition for computational security

Attempt 1

- **Goal**: Define the notion of computational security of an encryption scheme

- **Definition**: *An encryption scheme is secure iff no adversary can deduce the secret key when given access to a ciphertext*

Attempt 1

Stony Brook University

- **Goal**: Define the notion of computational security of an encryption scheme

- **Definition**: *An encryption scheme is secure iff no adversary can deduce the secret key when given access to a ciphertext*

Our goal is to protect the message not the key

Attempt 2

- **Goal**: Define the notion of computational security of an encryption scheme

- **Definition**: *An encryption scheme is secure iff no adversary can deduce the plaintext when given access to the ciphertext corresponding to that plaintext*

Attempt 2

Stony Brook University

- **Goal**: Define the notion of computational security of an encryption scheme

- **Definition**: *An encryption scheme is secure iff no adversary can deduce the plaintext when given access to the ciphertext corresponding to that plaintext*

What if I figure out only half of the plaintext message?

Attempt 3

- **Goal**: Define the notion of computational security of an encryption scheme

- **Definition**: *An encryption scheme is secure iff no adversary can deduce any character of the plaintext when given access to the ciphertext corresponding to that plaintext*

Attempt 3

Stony Brook University

- **Goal**: Define the notion of computational security of an encryption scheme

- **Definition**: *An encryption scheme is secure iff no adversary can deduce any character of the plaintext when given access to the ciphertext corresponding to that plaintext*

What if I figure out that the underlying message does not contain the word "BUY"?

Attempt 4

- **Goal**: Define the notion of computational security of an encryption scheme

- **Definition**: *An encryption scheme is secure iff no adversary can deduce any meaningful information about the plaintext when given access to the ciphertext corresponding to that plaintext*

Attempt 4

Stony Brook University

- **Goal**: Define the notion of computational security of an encryption scheme

- **Definition**: *An encryption scheme is secure iff no adversary can deduce any meaningful information about the plaintext when given access to the ciphertext corresponding to that plaintext*

What does *meaningful information* mean?

Semantic Security

- **Goal**: Define the notion of computational security of an encryption scheme
- **Definition**: *An encryption scheme is secure iff no adversary can compute any function of the plaintext when given access to the ciphertext corresponding to that plaintext*
- ***This notion of computational security is called the semantic security***

Semantic Security

Stony Brook University

- **Goal**: Define the notion of computational security of an encryption scheme
- **Definition**: *An encryption scheme is secure iff no adversary can compute any function of the plaintext when given access to the ciphertext corresponding to that plaintext*
- ***This notion of computational security is called the semantic security***

Silvio Micali and Shafi Goldwasser were awarded the Turing award for precisely defining security of cryptography

Semantic Security and Indistinguishability

- Our goal is to ensure that we use encryption schemes that have the semantic security
  - *Having access to the ciphertext does not help an adversary compute any function of the plaintext*
- **Equivalent notion**: *Computational Indistinguishability*
  - *Easier to prove the security of concrete schemes*

Semantic Security and Indistinguishability

- Our goal is to ensure that we use encryption schemes that have the semantic security
  - *Having access to the ciphertext does not help an adversary compute any function of the plaintext*
- **Equivalent notion**: *Computational Indistinguishability*
  - *Easier to prove the security of concrete schemes*

Adversary cannot distinguish between the ciphertexts of two plaintexts

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

Challenger

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

Challenger

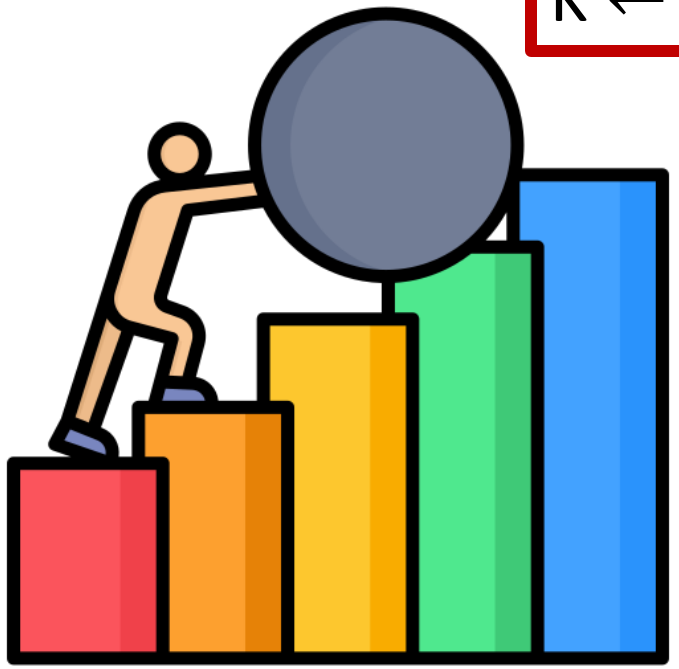
Adversary

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

$K \leftarrow \mathrm{KeyGen}(\lambda)$



Challenger

Adversary

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

$K \leftarrow \text{KeyGen}(\lambda)$

Challenger

$\text{Enc}_K[.]$

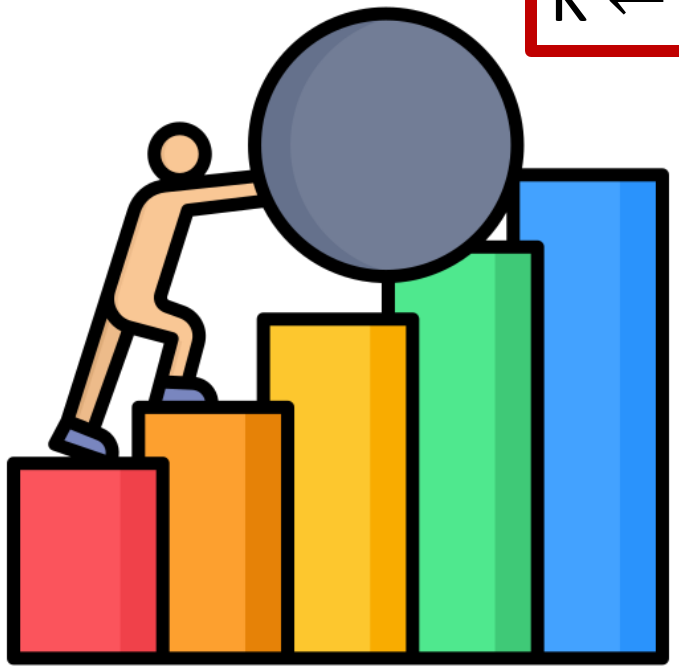
Adversary

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

$K \leftarrow \text{KeyGen}(\lambda)$



Challenger

$\text{Enc}_K[.]$

Query Phase

Adversary

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

$K \leftarrow KeyGen(\lambda)$

$Enc_K[.]$

Challenger

$m0, m1 \in M$

Adversary

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

$K \leftarrow KeyGen(\lambda)$

$Enc_K[.]$

Challenger

$m0, m1 \in M$

$Enc_K(m_b)$ where $b \in \{0,1\}$

Adversary

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

$K \leftarrow KeyGen(\lambda)$

$Enc_K[.]$

Challenger

$m0, m1 \in M$

$Enc_K(m_b)$ where $b \in \{0,1\}$

b' is a guess of b

Adversary

Towards IND-CPA Security

Stony Brook University

Ciphertext indistinguishability under chosen plaintext attack

$K \leftarrow KeyGen(\lambda)$

$Enc_K[.]$

Challenger

$m0, m1 \in M$

$Enc_K(m_b)$ where $b \in \{0,1\}$

b' is a guess of b

Adversary

Adversary cannot guess b with non-negligible probability

IND-CPA Details

Stony Brook University

- A key K is generated by Gen(λ) where λ is the security parameter (e.g., length of the key)
- **Query phase**: Adversary is given oracle access to $Enc_K(\cdot)$
  - **Oracle access**: one gets its question answered without knowing any additional information
- **Challenge phase**:
  - Adversary outputs a pair of equal-length messages m_0 and m_1
  - A random bit b is chosen, and adversary is given $Enc_k(m_b)$ which is the challenge ciphertext
- **Guess phase**: Adversary does any computation it wants, while still having oracle access to $Enc_k(\cdot)$, and outputs b'
- Adversary wins if b=b'

IND-CPA Details

Stony Brook University

- A key K is generated by Gen(λ) where λ is the security parameter (e.g., length of the key)
- **Query phase**: Adversary is given oracle access to $\mathrm{Enc}_K(\cdot)$
  - **Oracle access**: one gets its question answered without knowing any additional information
- **Challenge phase**:
  - Adversary outputs a pair of equal-length messages m_0 and m_1

Adversary's chance of winning is not better than just guessing.

$$\Pr[\text{Adversary winning this game} \leq \frac{1}{2} + \mathrm{negl}(\lambda)]$$

IND-CPA Details

Stony Brook University

- A key K is generated by Gen(λ) where λ is the security parameter (e.g., length of the key)
- **Query phase**: Adversary is given oracle access to $\mathrm{Enc}_K(\cdot)$
  - **Oracle access**: one gets its question answered without knowing any additional information
- **Challenge phase**:
  - Adversary outputs a pair of equal-length messages m_0 and m_1

Adversary's chance of winning is not better than just guessing.

$$\Pr[\text{Adversary winning this game} \leq \frac{1}{2} + \mathrm{negl}(\lambda)]$$

Insight of IND-CPA

- **Perfect secrecy** means that any plaintext is encrypted to a given ciphertext with the same probability
  - Given any pair of M_0 and M_1, the probabilities that they are encrypted into a ciphertext C are the same
  - Hence, no adversary (*with no restrictions on computing power*) can tell whether C is ciphertext of M_0 or M_1.

- **IND-CPA** means
  - With *bounded computational resources*, the adversary cannot tell which of M_0 and M_1 is encrypted in C

Comparison

- If a cipher has only computational security, then it can be broken by a brute force attack (e.g., enumerating all possible keys)
  - Weak algorithms can be broken with much less time
- **How to prove computational security?**
  - Assume that some problems are hard (requires a lot of computational resources to solve), then show that breaking security means solving the problem

Comparison

- If a cipher has only computational security, then it can be broken by a brute force attack (e.g., enumerating all possible keys)
  - Weak algorithms can be broken with much less time
- **How to prove computational security?**
  - Assume that some problems are hard (requires a lot of computational resources to solve), then show that breaking security means solving the problem

Computational security is foundation of modern cryptography.

Summary of Cipher Security

Stony Brook University

- Stream ciphers can be used to achieve IND-CPA security when the underlying PRNG is cryptographically strong
- **ECB does not have semantic security**
  - *How to break the semantic security (IND-CPA) of a block cipher with ECB?*
- CBC is proven to provide IND-CPA assuming that the block cipher is secure, and that IV's are randomly chosen
- CTR is proven IND-CPA secure assuming that block cipher is secure, and that IV's are randomly chosen

Summary of Cipher Security

Stony Brook University

- Stream ciphers can be used to achieve IND-CPA security when the underlying PRNG is cryptographically strong
- **ECB does not have semantic security**
  - *How to break the semantic security (IND-CPA) of a block cipher with ECB?*
- CBC is proven to provide IND-CPA assuming that the block cipher is secure, and that IV's are randomly chosen
- CTR is proven IND-CPA secure assuming that block cipher is secure, and that IV's are randomly chosen

Interesting paper on probabilistic encryption:
https://groups.csail.mit.edu/cis/pubs/shafi/1984-jcss.pdf

What does secure comm mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **<u>security of communication</u>** over **insecure medium**
- What does secure communication mean?
  - **Confidentiality** (secrecy)
    - Only the intended receiver can understand the meaning of a secret communication
  - **Integrity** (authenticity)
    - The communication is generated by the alleged sender
    - *<u>Any unauthorized perturbation of the communication can be detected by the receiver</u>*

What does secure comm mean?

Stony Brook University

- **Fundamental problem of cryptography:**
  - Ensure **<u>security of communication</u>** over **insecure medium**
- What does secure communication mean?
  - **Confidentiality** (secrecy)
    - Only the intended receiver can understand the meaning of a secret communication
  - **Integrity** (authenticity)
    - The communication is generated by the alleged sender
    - *<u>Any unauthorized perturbation of the communication can be detected by the receiver</u>*

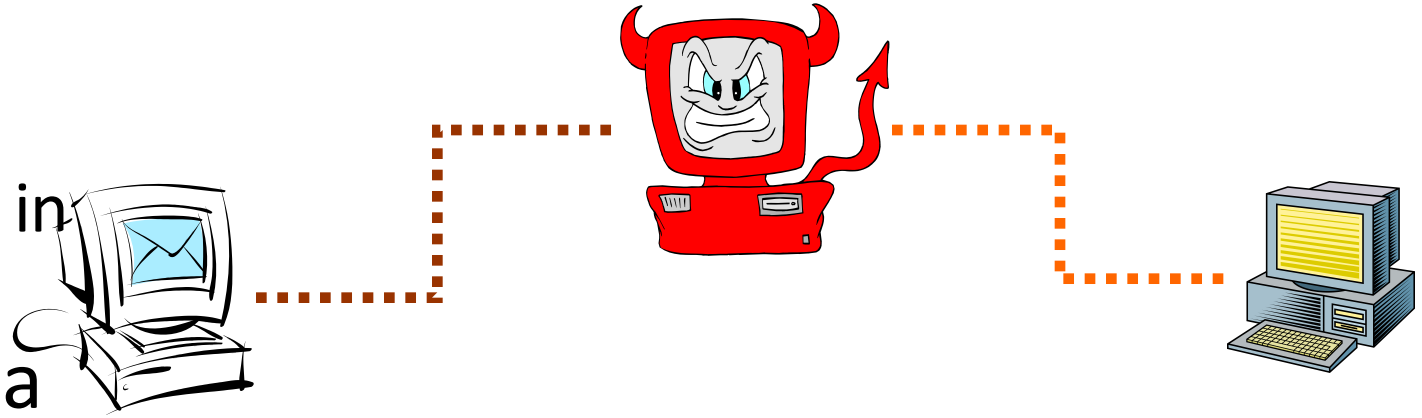
Cryptographic Hash Function and Message Authentication Code

Data Integrity and Source Authentication

Stony Brook University

- Encryption does not protect data from modification by another party

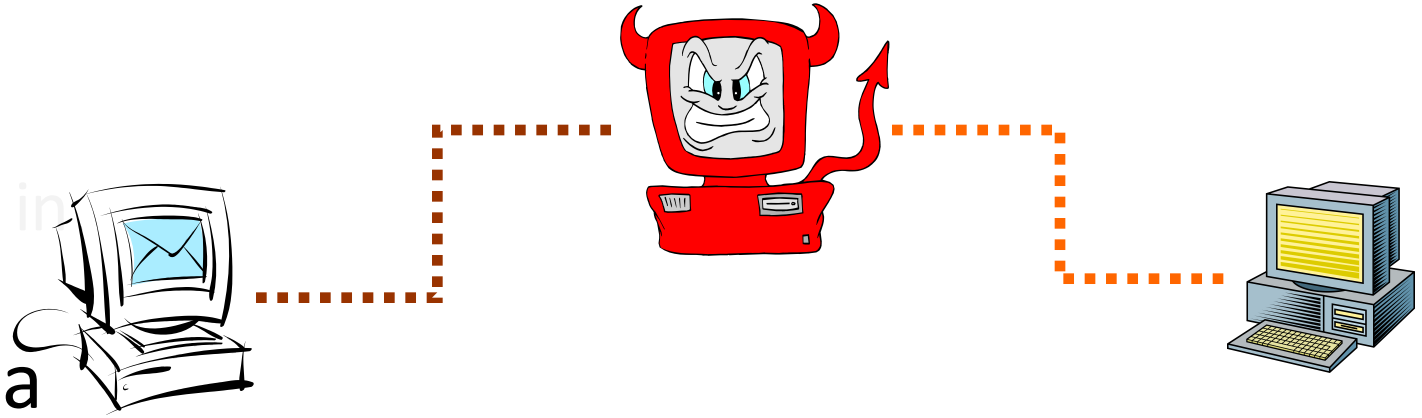
- Most encryption schemes are **malleable**
  - Modifying ciphertext results in (somewhat) predictable change in plaintext
- Need a way to ensure that data arrives at destination in its original form as sent by the sender



Data Integrity and Source Authentication

Stony Brook University

- Encryption does not protect data from modification by another party
- Most encryption schemes are **malleable**
  - Modifying ciphertext results in (somewhat) predictable change in plaintext

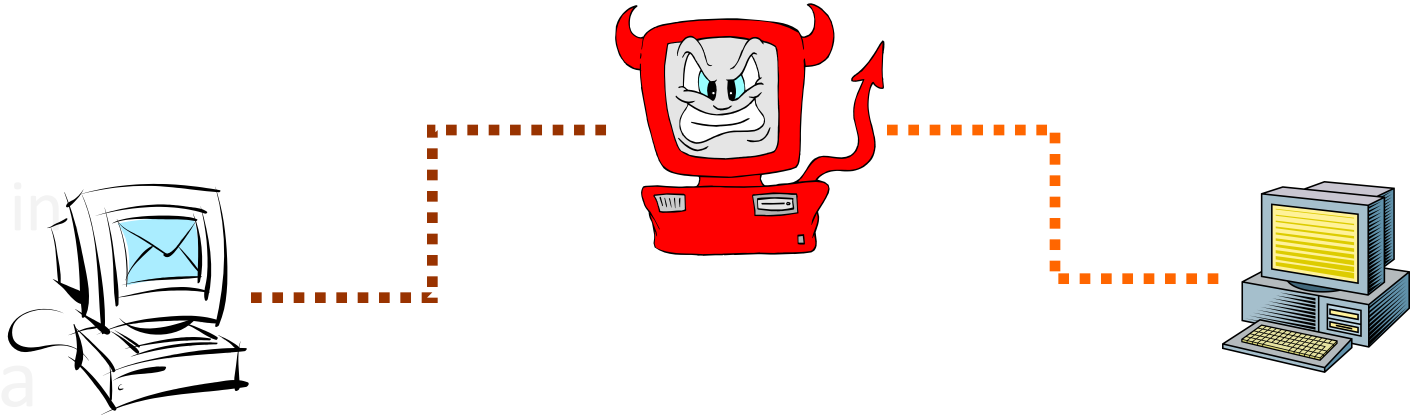


- Need a way to ensure that data arrives at destination in its original form as sent by the sender

Data Integrity and Source Authentication

Stony Brook University

- Encryption does not protect data from modification by another party
- Most encryption schemes are **malleable**
  - Modifying ciphertext results in (somewhat) predictable change in plaintext
- Need a way to ensure that data arrives at destination in its original form as sent by the sender



Hash Functions

Stony Brook University

- A hash function maps a message of an **arbitrary length** to a **fixed m-bit output**
  - Output of a hash function is known as the **fingerprint** or the **message digest**

- *What is an example of hash functions?*
  - Give a hash function that maps Strings to integers in $[0,2^{32}-1]$

- **Cryptographic hash functions are hash functions with additional security requirements**

Hash function for Message Integrity

Stony Brook University

- **<u>Method 1</u>** : Use a hash function h, assuming an authentic (adversary cannot modify) channel for short messages
  - Transmit a message M over the normal (insecure) channel
  - Transmit the message digest h(M) over the authentic channel
  - When receiver receives both M' and h, how does the receiver check to make sure the message is unmodified?
- **Is this secure?**

Hash function for Message Integrity

Stony Brook University

- **<u>Method 1</u>** : Use a hash function h, assuming an authentic (adversary cannot modify) channel for short messages
  - Transmit a message M over the normal (insecure) channel
  - Transmit the message digest h(M) over the authentic channel
  - When receiver receives both M' and h, how does the receiver check to make sure the message is unmodified?
- **Is this secure?**

A hash function is a many-to-one function, so **collision can happen**, thanks to the Pigeonhole principle

Security Requirements

Stony Brook University

Given a function $h:X \rightarrow Y$, then we say that h is:

- **Preimage resistant (one-way):**

  if given $y \in Y$ it is computationally infeasible to find a value $x \in X$ s.t. $h(x) = y$

- **2nd preimage resistant (weak collision resistant):**

  if given $x \in X$ it is computationally infeasible to find a value $x' \in X$, s.t. $x' \neq x$ and $h(x') = h(x)$

- **Collision resistant (strong collision resistant):**

  if it is computationally infeasible to find two distinct values $x', x \in X$, s.t. $h(x') = h(x)$

Usage of Hash Functions

Stony Brook University

- Software integrity
  - E.g., tripwire
- Timestamping (**Cryptographic commitment**)
  - **How to prove that you have discovered a secret on an earlier date without disclosing the context of a secret?**
- Authenticating logs (a long history of events)
- **Covered later**
  - Message authentication
  - One-time passwords
  - Digital signature

Bruteforce Attacks on Hash Functions

- ***Attacking one-wayness***
  - **<u>Goal</u>**: Given $h:X \rightarrow Y$, $y \in Y$, find x such that $h(x)=y$
  - **<u>Algorithm</u>**:
    - Pick a random value x in X, check if $h(x)=y$, if $h(x)=y$, returns x; otherwise iterate
    - After failing q iterations, return fail
  - The average-case success probability is

$$\varepsilon = 1 - \left(1 - 1/|Y|\right)^q \approx 1 - e^{-\frac{q}{|Y|}} \approx \frac{q}{|Y|}$$

    - The first approximation holds when $|Y|$ is large,
    - The second roughly holds when $q/|Y|$ is small (e.g., < 0.5)
  - Let $|Y|=2^m$, to get ε to be close to 0.5, $q \approx 2^{m-1}$

Bruteforce Attacks on Hash Functions

- ***Attacking collision resistance***
  - **Goal:** Given h, find x, x' such that h(x)=h(x')
  - **Algorithm:**
  - Pick a random set X_0 of q values in X
  - For each $x \in X_0$, computes $y_x = h(x)$

    if $y_x = y_{x'}$ for some $x' \neq x$ then return (x,x')

    else fail

  - The average success probability is $$1-\left(1-\frac{1}{|Y|}\right)^{\frac{q(q-1)}{2}} \approx 1-e^{-\frac{q(q-1)}{2|Y|}}$$

  - Let $|Y|=2^m$, to get ε to be close to 0.5, $q \approx 2^{m/2}$
  - This is known as the **birthday attack**.

Choosing Parameters

- The level of security (for collision resistance) of a hash function that outputs n bits, is about $\frac{n}{2}$ bits
  - i.e., it takes $2^{n/2}$ time to bruteforce it
  - Assuming that no better ways of attacking the hash function is known
- **Longer outputs often means more computation time and more communication overhead**
- *The level of security for encryption function using k-bit key is about k bits*

Length of Hash Outputs

Stony Brook University

- **The Weakest Link Principle:**
  - *A system is only as secure as its weakest link*.
  - Hence all links in a system should have similar levels of security.
- Because of the birthday attack, the length of hash outputs in general should double the key length of block ciphers
  - SHA-224 matches the 112-bit strength of triple-DES (encryption 3 times using DES)
  - SHA-256, SHA-384, SHA-512 match the new key lengths (128,192,256) in AES
  - ***If small output size is highly important, and one is sure that collision-resistance is not needed (only one-wayness is needed), then same size should be okay.***

Well known Hash Functions

- **MD5**
  - Output 128 bits
  - Collision resistance completely broken by researchers in 2004
  - One-wayness theoretically broken in 2009
- **SHA1**
  - Output 160 bits
  - Collision found by Google: **SHATTERED** (https://shattered.io/)
  - Considered insecure for collision resistance
  - One-wayness still holds
- SHA2 (SHA-224, SHA-256, SHA-384, SHA-512)
  - Outputs 224, 256, 384, and 512 bits, respectively
  - No real security concerns yet
- SHA3 (224, 256, 384, 512)

Hash Function for Authentication

Stony Brook University

- **Require an authentic channel to transmit the hash of a message**
  - Without such a channel, it is insecure, because anyone can compute the hash value of any message, as the hash function is public
  - *Such a channel may not always exist*

- **How to address this?**
  - Use more than one hash functions
  - Use a key to select which of the hash function to use

Hash Family

Stony Brook University

- A hash family is a four-tuple (X,Y,K,H), in which
  - $\boldsymbol{X}$ is a set of possible messages
  - $\boldsymbol{Y}$ is a finite set of possible message digests
  - $\boldsymbol{K}$ is the key space
  - For each $K \in K$, there is a hash function $h_K \in H$. **Each h_K: $\boldsymbol{X} \rightarrow \boldsymbol{Y}$**
- Alternatively, one can think of H as a function $K \times X \rightarrow Y$

Message Authentication Code (MAC)

Stony Brook University

- A MAC scheme is a hash family, used for message authentication
- **MAC(K,M) = H_K(M)**
- The sender and the receiver share secret K
- The sender sends (M, H_k(M))
- The receiver receives (X,Y) and verifies that H_K(X)=Y, if so, then accepts the message as from the sender
- **To be secure, an adversary shouldn't be able to come up with (X',Y') such that H_K(X')=Y'.**

Message Authentication Code (MAC)

Stony Brook University

- A MAC scheme is a hash family, used for message authentication
- **$MAC(K,M) = H_K(M)$**
- The sender and the receiver share secret K
- The sender sends $(M, H_k(M))$
- The receiver receives (X,Y) and verifies that $H_K(X)=Y$, if so, then accepts the message as from the sender
- **To be secure, an adversary shouldn't be able to come up with (X',Y') such that $H_K(X')=Y'$.**

MAC: Using a shared secret (or a limit-bandwidth confidential channel) to achieve authenticity/integrity.

Security Requirements for MAC

Stony Brook University

- Secure against the "Existential Forgery under Chosen Plaintext Attack"
- EUF-CMA (**E**xistential **U**n**f**orgeability under **C**hosen **M**essage **A**ttack)
  - Challenger chooses a random key K
  - Adversary chooses a number of messages M_1, M_2, .., M_n, and obtains t_j=MAC(K,M_j) for $1 \leq j \leq n$
  - Adversary outputs M' and t'
  - Adversary wins if $\forall j$ $M' \neq M_j$, and t'=MAC(K,M')

- **Basically, adversary cannot create the MAC value for a message for which it hasn't seen an MAC**

MAC from a Block MAC

Stony Brook University

- **Given**: A block MAC $MAC_B(.,.)$ that can create a secure MAC of only one block of message M in which the block size is $\mathbb{L}$
- **Goal**: Create a MAC $MAC_{full}(.,.)$ that can create a secure MAC of message with arbitrary length

MAC from a Block MAC

Stony Brook University

- **Given**: A block MAC $MAC_B(.,.)$ that can create a secure MAC of only one block of message M in which the block size is $\mathbb{L}$
- **Goal**: Create a MAC $MAC_{full}(.,.)$ that can create a secure MAC of message with arbitrary length
- **Constructing $MAC_{full}(.,.)$ from $MAC_B(.,.)$**:
  - Divide up the message into block size pieces $M=M_1M_2...M_n$ where $|M_1|=|M_2|=...=|M_n|=\mathbb{L}$
  - **Approach 1**: $MAC_B(K, M_1 \oplus M_2 \oplus M_3 \oplus ... \oplus M_n)$
  - **Approach 2**: $MAC_B(K,M_1) \oplus MAC_B(K,M_2) \oplus ... \oplus MAC_B(K,M_n)$
  - **Approach 3**: $MAC_B(K,M_1||1) \oplus MAC_B(K,M_2||2) \oplus ... \oplus MAC_B(K,M_n||n)$

MAC from a Block MAC

Stony Brook University

- **Given**: A block MAC $MAC_B(.,.)$ that can create a secure MAC of only one block of message M in which the block size is $\mathbb{L}$
- **Goal**: Create a MAC $MAC_{full}(.,.)$ that can create a secure MAC of message with arbitrary length
- **Constructing $MAC_{full}(.,.)$ from $MAC_B(.,.)$**:
  - Divide up the message into block size pieces $M=M_1M_2...M_n$ where $|M_1|=|M_2|=...=|M_n|=\mathbb{L}$
  - **Approach 1**: $MAC_B(K, M_1 \oplus M_2 \oplus M_3 \oplus ... \oplus M_n)$
  - **Approach 2**: $MAC_B(K,M_1) \oplus MAC_B(K,M_2) \oplus ... \oplus MAC_B(K,M_n)$
  - **Approach 3**: $MAC_B(K, M_1||1) \oplus MAC_B(K, M_2||2) \oplus$

Are they secure?

Possible Solution

Stony Brook University

- **None of the previous 3 approaches are secure with respect to EUF-CMA security definition**
- Authenticate each block in the following way:
  - Authenticate each block in the following way:
  - Tag = **<r, MAC_B(K, r || L || *i* || M_i)>**
  - r is a fresh random value; similar to IV
  - L is the length of the message
  - i is the index of the message block for which the block MAC is being calculated

MAC from Hash Function

Stony Brook University

- Let h be a one-way hash function

- **Failed approach**: *MAC(K,M) = h(K || M)*, where || denote concatenation
  - Insecure as MAC with a hash function that uses the Merkle-Damgard construction:
  - Given M and t=h(K || M), adversary can compute M'=M||Pad(M)||X and t', such that h(K||M') = t'

HMAC: MAC from Hash Functions

$$\mathbf{HMAC_K[M] = Hash[(K^+ \oplus opad) \,||\, Hash[(K^+ \oplus ipad)||M)]]}$$

HMAC: MAC from Hash Functions

Stony Brook University

$$\mathbf{HMAC_K[M] = Hash[(K^+ \oplus opad) \,||\, Hash[(K^+ \oplus ipad)||M)]]}$$

- **K^+** is the key padded (with 0) to B bytes, the input block size of the hash function
- **ipad** = the byte 0x36 repeated B times
- **opad** = the byte 0x5C repeated B times.

HMAC: MAC from Hash Functions

Stony Brook University

$$\mathbf{HMAC_K[M] = Hash[(K^+ \oplus opad) \,||\, Hash[(K^+ \oplus ipad)||M)]]}$$

- **K^+** is the key padded (with 0) to B bytes, the input block size of the hash function
- **ipad** = the byte 0x36 repeated B times
- **opad** = the byte 0x5C repeated B times.

At high level, $HMAC_K[M] = H(K \,||\, H(K \,||\, M))$

Hash function is used twice, in nested fashion.

HMAC Security

- HMAC must satisfy the EUF-CMA Security Definition to be considered secure.

- **Practical aspect:** *When an HMAC is instantiated with secure hash functions (e.g., SHA-256), and according to the specification (e.g., key size, correct output size), then no practical attacks are known against HMAC.*

MAC from Block Cipher

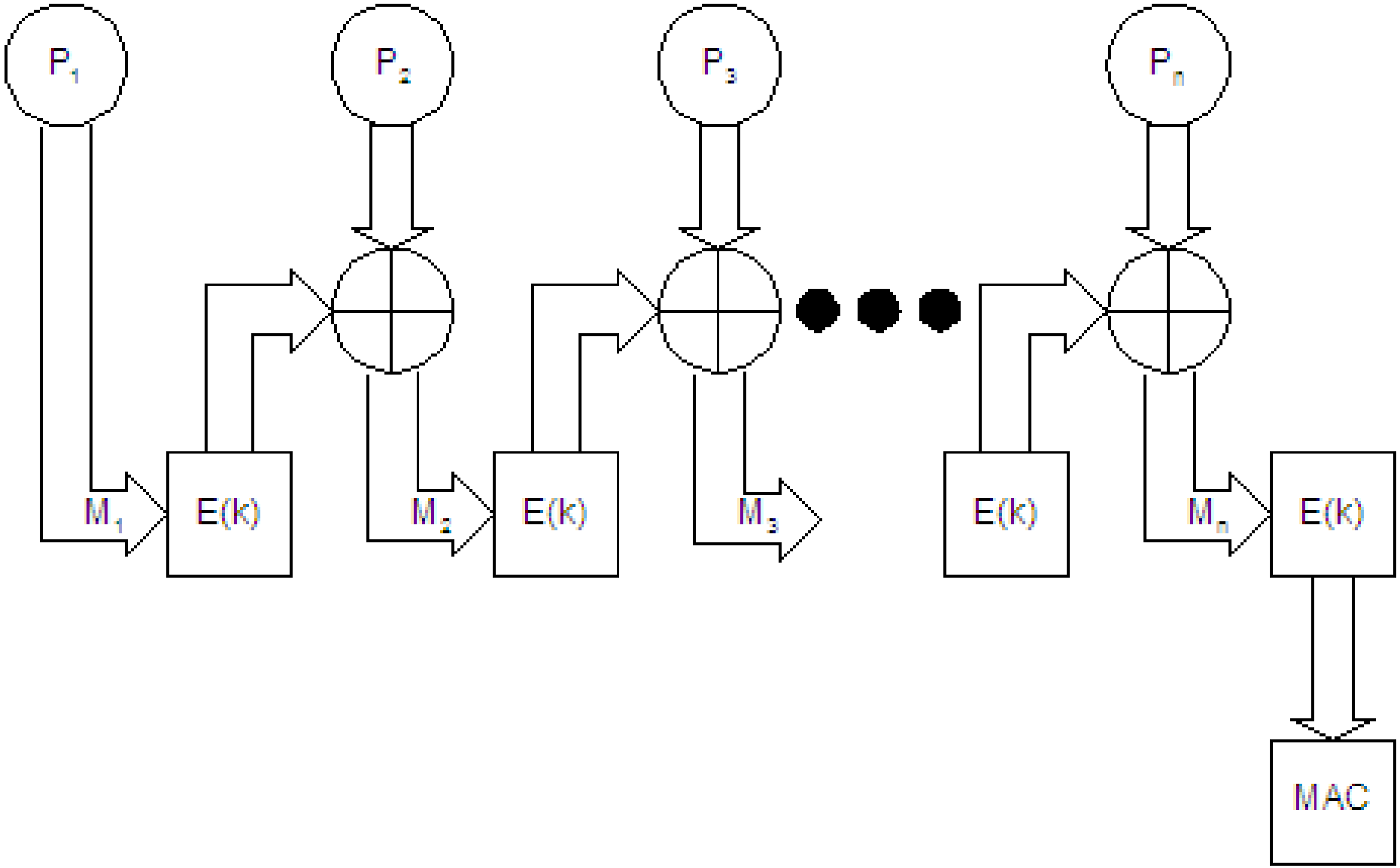
Stony Brook University

- **One can construct a MAC from a block cipher**
- The CBC mode can be used to define the CBC-MAC (which we will see in a bit)
- **GCM (Galois/Counter Mode) of encryption** is widely used because it provides message authentication and encryption at the same time.

MAC from Block Cipher

Stony Brook University

- **One can construct a MAC from a block cipher**
- The CBC mode can be used to define the CBC-MAC (which we will see in a bit)
- **GCM (Galois/Counter Mode) of encryption** is widely used because it provides message authentication and encryption at the same time.

Encryption schemes like AES GCM are generally called Authenticated Encryption. Other such examples include AES CCM, CWC, OCB, EAX, ChaCha20-Poly1305

CBC-MAC